

SE2026 股票交易系统 交易系统管理业务

【股票交易系统】

——交易系统管理业务

测试报告

组长：孙米阳

组员：郝建文 黄中维 杨佳利 陆思越

日期：2026 年 6 月 22 日

目录

1 引言	5
1.1 编写目的	5
1.2 项目背景	5
1.2.1 软件系统名称	5
1.2.2 任务提出者	5
1.2.3 开发者	5
1.2.4 目标用户	5
1.2.5 项目相关背景介绍	5
1.3 术语与缩写解释	5
1.4 系统概述	6
1.4.1 整体系统概述	6
1.4.2 交易系统管理业务 概述	6
1.4.3 关键数据模型	6
1.4.4 架构概览	6
1.5 测试对象——交易系统管理业务 说明	6
1.6 测试策略	7
1.6.1 测试层次	7
1.6.2 测试优先级	7
1.6.3 测试类型	7
1.7 测试环境	8
1.7.1 测试拓扑	8
1.7.2 依赖与配置	8
1.7.3 测试数据	8
1.8 测试内容	8
1.9 测试设备	9
1.9.1 硬件设备	9
1.9.2 软件设备	9
2 模块功能测试	10
2.1 模块说明	10
2.2 认证模块（Auth）功能测试	10
2.2.1 API 端点	10
2.2.2 测试用例	10
2.2.3 测试结果	11
2.2.4 测试结果分析	12
2.2.5 测试结果截图	12
2.3 股票查看模块（Stocks）功能测试	14
2.3.1 API 端点	14
2.3.2 测试用例	14
2.3.3 测试结果	15
2.3.4 测试结果分析	15
2.3.5 测试结果截图	16
2.4 涨跌停设置模块（Limits）功能测试	18
2.4.1 API 端点	18
2.4.2 测试用例	18
2.4.3 测试结果	18
2.4.4 测试结果分析	19
2.4.5 测试结果截图	19
2.5 交易控制模块（Trade Control）功能测试	21
2.5.1 API 端点	21
2.5.2 测试用例	21
2.5.3 测试结果	21
2.5.4 测试结果分析	22

2.5.5 测试结果截图	22
2.6 交易日管理模块 (Trading Days) 功能测试	23
2.6.1 API 端点	23
2.6.2 测试用例	23
2.6.3 测试结果	23
2.6.4 测试结果分析	24
2.6.5 测试结果截图	24
2.7 密码管理模块 (Password) 功能测试	25
2.7.1 API 端点	25
2.7.2 测试用例	25
2.7.3 测试结果	25
2.7.4 测试结果分析	25
2.7.5 测试结果截图	25
2.8 权限管理模块 (Permissions) 功能测试	27
2.8.1 API 端点	27
2.8.2 测试用例	27
2.8.3 测试结果	28
2.8.4 测试结果分析	28
2.8.5 测试结果截图	29
2.9 审计日志模块 (Audit) 功能测试	30
2.9.1 API 端点	30
2.9.2 测试用例	30
2.9.3 测试结果	31
2.9.4 测试结果分析	31
2.9.5 测试结果截图	32
2.10 健康检查模块 (Health Check) 功能测试	33
2.10.1 API 端点	33
2.10.2 测试用例	33
2.10.3 测试结果	33
2.10.4 测试结果分析	33
2.10.5 测试结果截图	33
3 边界值测试	35
3.1 测试说明	35
3.2 认证模块边界值测试	35
3.2.1 测试用例	35
3.2.2 测试结果	35
3.2.3 测试结果分析	36
3.2.4 测试结果截图	36
3.3 涨跌停设置模块边界值测试	39
3.3.1 测试用例	39
3.3.2 测试结果	39
3.3.3 测试结果分析	39
3.3.4 测试结果截图	39
3.4 搜索与审计模块边界值测试	40
3.4.1 测试用例	40
3.4.2 测试结果	40
3.4.3 测试结果分析	40
3.4.4 测试结果截图	40
4 API 集成测试	41
4.1 测试说明	41
4.2 统一响应格式	41
4.3 实际测试脚本结构	41
4.4 关键 Test Fixture 设计	41
4.5 测试结果汇总	42

5	前端 / E2E 测试	43
5.1	页面清单	43
5.2	前端功能测试要点	43
5.3	前端测试结果	43
5.4	E2E 测试建议	44
6	安全性测试	45
6.1	认证安全测试	45
6.2	授权安全测试	45
6.3	安全性测试结果汇总	45
7	性能测试	47
7.1	测试简介	47
7.2	烟雾测试结果	47
7.3	测试结果	47
7.3.1	测试结果数据	47
8	其他模块接口测试	48
8.1	测试简介	48
8.2	测试对象说明	48
8.3	控制	48
8.4	测试内容	48
8.4.1	数据库接口测试	48
8.4.2	外部 API 接口测试 (ADMIN 调用 TRADE)	49
8.4.3	认证与权限接口测试	49
8.5	测试结果汇总	50
9	对软件功能的结论	51
9.1	认证功能	51
9.1.1	能力	51
9.1.2	限制	51
9.2	股票查看功能	51
9.2.1	能力	51
9.2.2	限制	51
9.3	涨跌停设置功能	51
9.3.1	能力	51
9.3.2	限制	51
9.4	交易控制功能	51
9.4.1	能力	51
9.4.2	限制	51
9.5	密码管理功能	52
9.5.1	能力	52
9.5.2	限制	52
9.6	权限管理功能	52
9.6.1	能力	52
9.6.2	限制	52
9.7	审计功能	52
9.7.1	能力	52
9.7.2	限制	52
10	分析摘要	53
10.1	能力	53
10.2	缺陷和限制	53
10.3	小结	53

1 引言

1.1 编写目的

本测试报告为股票交易系统 交易系统管理业务 的测试报告，目的在于总结测试阶段出现的问题，检测系统是否达到预期功能目标，以验证系统能否按预期实现相关功能。报告总结了测试阶段中的详细步骤和测试结果，并对需求是否得到满足进行了评估。

本报告预期的参考人员包括软件客户、项目经理、项目开发人员、软件质量分析人员、系统维护人员等。

1.2 项目背景

1.2.1 软件系统名称

股票交易系统——交易系统管理业务

1.2.2 任务提出者

软件工程基础课程教学组

1.2.3 开发者

孙米阳、郝建文、黄中维、杨佳利、陆思越

1.2.4 目标用户

股票交易所内部管理员（普通管理员、高级管理员、系统管理员、审计管理员）

1.2.5 项目相关背景介绍

本项目为软件工程基础课程实验项目，属于“股票交易系统”五组协作项目中的交易系统管理业务子系统。五组分工如下：

- 1) 交易系统管理（**ADMIN** - 本组）：管理员登录、权限管理、股票查看、涨跌停设置、交易控制、交易日管理、审计日志。
- 2) 中央交易系统（**TRADE**）：指令接收与校验、订单簿维护、撮合引擎、成交回报、行情数据生成与推送。
- 3) 账户业务子系统（**ACCOUNT**）：资金账户与证券账户管理、认证、资金/证券冻结与结算。
- 4) 网上信息发布（**INFO**）：普通/VIP 用户体系、行情查询、K 线展示。
- 5) 交易客户端（**CLIENT**）：投资者侧交互界面，下单、撤单、查看持仓与成交。

1.3 术语与缩写解释

缩写、术语及符号	解释
SRS	软件需求规格说明书（Software Requirements Specification）。
RBAC	基于角色的访问控制（Role-Based Access Control），通过角色划分管理用户权限。
API	应用程序编程接口（Application Programming Interface），定义系统内外部交互的接口规范。
TRADE	中央交易系统（Central Trading System），负责指令接收、撮合、成交、行情推送。
ADMIN	交易系统管理业务子系统，负责管理员登录、权限管理、交易控制等。
ACCOUNT	账户业务子系统，管理资金账户、证券账户与认证。
INFO	网上信息发布子系统，面向普通/VIP 用户提供行情查询与 K 线展示。
CLIENT	交易客户端，投资者侧的交互界面。
JWT	JSON Web Token，用于无状态身份认证的令牌格式。
ORM	对象关系映射（Object-Relational Mapping），通过 SQLAlchemy 访问 MySQL。
SQL 注入	一种代码注入攻击技术，攻击者通过在输入中插入恶意 SQL 语句来操纵数据库。
XSS	跨站脚本攻击（Cross-Site Scripting），攻击者向 Web 页面注入恶意脚本。
CSV	逗号分隔值（Comma-Separated Values），一种通用数据交换格式。
E2E	端到端测试（End-to-End Testing），模拟真实用户操作流程的测试方法。

1.4 系统概述

1.4.1 整体系统概述

股票交易系统 是一个模拟的证券交易平台，由五个子系统协作构成：交易系统管理（ADMIN）、中央交易系统（TRADE）、账户业务（ACCOUNT）、网上信息发布（INFO）、交易客户端（CLIENT）。系统支持投资者开户、登录、下单、撤单、行情查看、成交查询等功能，同时为交易所管理员提供权限管理、涨跌停设置、交易控制等后台管理功能。

1.4.2 交易系统管理业务 概述

交易系统管理业务 面向股票交易所内部管理员，采用基于角色的访问控制（RBAC），按职责划分为四类角色：

- 1) 普通管理员（**NORMAL_ADMIN**，编码 **0**）：查看授权范围内的股票列表、实时行情与交易明细。
- 2) 高级管理员（**SENIOR_ADMIN**，编码 **1**）：除普通管理员权限外，还具备涨跌停比例设置、交易暂停/重启、交易日开始/结束的控制权限。
- 3) 系统管理员（**SYSTEM_ADMIN**，编码 **2**）：负责管理员账号的创建、角色分配、授权股票范围配置及账号状态管理。
- 4) 审计管理员（**AUDIT_ADMIN**，编码 **3**）：具有只读权限，查看全局操作日志与登录日志，支持筛选与导出。

系统共划分为八个功能模块：认证管理、股票查看、涨跌停设置、交易控制、交易日管理、密码管理、权限管理、审计日志。

1.4.3 关键数据模型

模型	表名	说明
Admin	admin_info	管理员账户信息，含角色、状态、锁定等字段
PermissionConfig	permission_config	管理员股票授权范围配置
LoginLog	login_log	登录/登出日志记录
OperationLog	operation_log	操作审计日志记录

1.4.4 架构概览

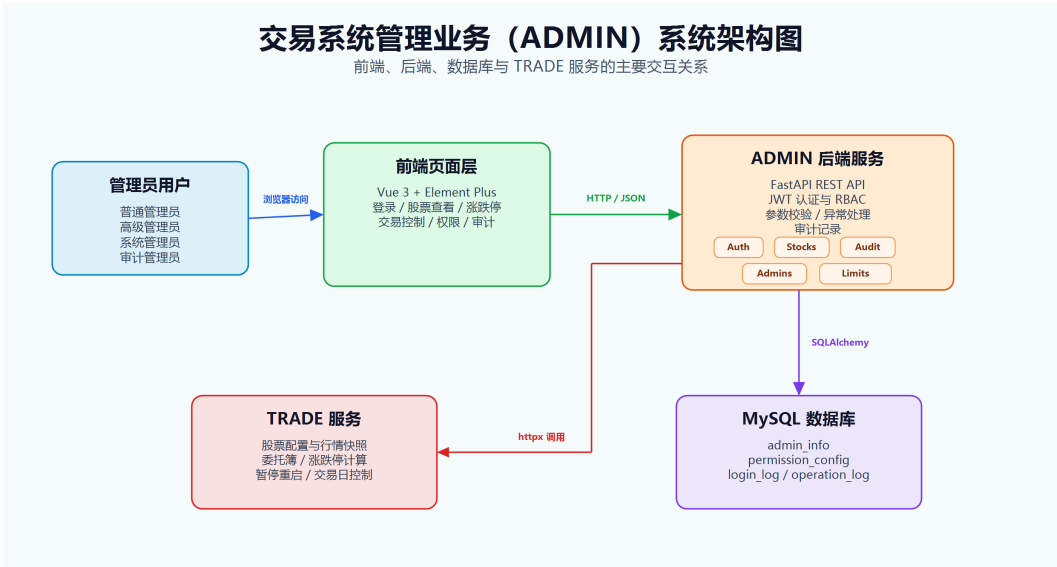


图 1 交易系统管理业务（ADMIN）系统架构图

ADMIN 子系统采用前后端分离的 B/S 架构。后端为 FastAPI + MySQL，前端为 Vue 3 + Element Plus。ADMIN 通过 httpx 异步 HTTP 客户端调用 TRADE 的外部 API。测试时需要同时关注后端 API、前端页面以及 ADMIN ↔ TRADE 的集成交互。

1.5 测试对象——交易系统管理业务 说明

本测试针对股票交易系统 交易系统管理业务 进行，测试范围涵盖以下后端 API 模块和前端页面：

后端模块（8 个）：

- 1) 认证模块 (**Auth**)：管理员登录/登出、密码修改、获取当前用户信息。
- 2) 股票查看模块 (**Stocks**)：按授权范围展示股票列表、实时行情与委托簿查询。
- 3) 涨跌停设置模块 (**Limits**)：管理股票涨跌幅比例设置，调用 TRADE 完成价格计算。
- 4) 交易控制模块 (**Trade Control**)：执行股票的暂停/重启撮合操作。
- 5) 交易日管理模块 (**Trading Days**)：交易日开始/结束控制。
- 6) 权限管理模块 (**Permissions**)：管理员角色、授权范围与账号状态配置。
- 7) 审计日志模块 (**Audit**)：操作日志与登录日志的查看、筛选、导出与删除。
- 8) 健康检查模块 (**Health Check**)：服务健康状态及依赖检测。

前端页面 (7 个)：

- 1) /login — 登录页
- 2) /stocks — 股票查看
- 3) /limits — 涨跌停设置
- 4) /trade-control — 交易控制
- 5) /permissions — 权限管理
- 6) /audit — 审计日志
- 7) /password — 密码修改

1.6 测试策略

1.6.1 测试层次

层次	说明
单元测试	pytest 对业务逻辑层、工具函数进行测试
集成测试	pytest + httpx 对 API 级别进行测试 (核心)
E2E 测试	Playwright / Cypress 进行冒烟级别的端到端测试

1.6.2 测试优先级

优先级	模块	理由
P0	Auth (登录/鉴权)	所有接口的前置依赖
P0	角色权限控制	安全核心
P1	涨跌停设置	交易核心管理功能
P1	交易控制 (暂停/重启)	交易核心管理功能
P1	交易日管理	交易核心管理功能
P2	股票查看	基础展示功能
P2	权限管理	管理员运维功能
P2	审计日志	审计与追溯功能
P3	健康检查	运维监控辅助

1.6.3 测试类型

- 1) 功能测试：手动 + 自动化，覆盖所有 API 端点；
- 2) 边界测试：输入边界、权限边界、状态边界；
- 3) 异常测试：网络异常、数据库异常、上游服务异常；
- 4) 安全测试：未授权访问、越权操作、Token 伪造/过期、SQL 注入、XSS；
- 5) 性能测试：并发登录、日志大数据量查询、CSV 导出。

1.7 测试环境

1.7.1 测试拓扑

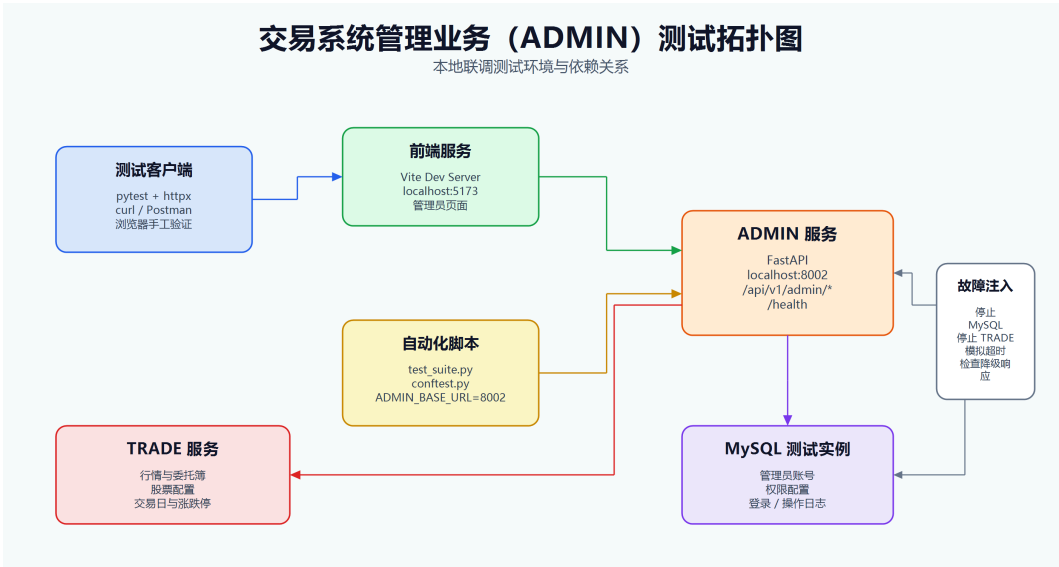


图 2 交易系统管理业务 (ADMIN) 测试拓扑图

测试拓扑由以下组件构成：测试客户端（curl / pytest / 浏览器）→ ADMIN 服务（localhost:8002）→ MySQL 测试实例 + TRADE 服务。

1.7.2 依赖与配置

组件	版本要求	说明
Python	≥ 3.10	后端运行环境
Node.js	≥ 18	前端构建环境
MySQL	≥ 8.0	数据持久化
FastAPI	≥ 0.110.0	Web 框架
Vue 3	最新稳定版	前端框架
Element Plus	最新稳定版	UI 组件库

1.7.3 测试数据

使用 seed.py 预置的四类管理员账号：

用户名	密码	角色
normal_admin	Admin@123	NORMAL_ADMIN（普通管理员）
senior_admin	Admin@123	SENIOR_ADMIN（高级管理员）
sys_admin	Admin@123	SYSTEM_ADMIN（系统管理员）
audit_admin	Admin@123	AUDIT_ADMIN（审计管理员）

1.8 测试内容

测试名称	目的	内容
模块功能测试	检测各个模块的功能是否全部实现	根据需求规格说明书和系统设计报告的要求针对各个模块进行功能测试，尽可能保证测试项覆盖所有功能和各种功能条件组合。
边界值测试	检测系统能否正常处理边界值	在一些存在边界值问题的数据里分别输入边界值，观察系统反应，检测系统的应对能力。
压力测试	测试系统的承受能力	对子系统进行超过规定性能指标的测试，包括系统能够在压力过程中避免明显的性能下降，以及在压力后的及时恢复。

模块接口测试	测试与其他模块的接口是否完好，能否最后实现集成测试	运行本子系统，观察数据库里的数据变化，检查子系统间的交互，验证 TRADE 接口联调是否正常。
安全性测试	检测系统的安全防护能力	测试 JWT 认证机制、URL 防篡改、SQL 注入防护、角色权限隔离、XSS 防护等安全措施的完备性。

1.9 测试设备

1.9.1 硬件设备

- 1) 个人计算机（CPU 4 核 2.6GHz 以上，内存 8.0GB 以上，硬盘可用空间不小于 50GB）
- 2) 局域网环境（千兆以太网，与 TRADE 子系统内网互通）

1.9.2 软件设备

- 1) 操作系统：Windows 10/11
- 2) 浏览器：
 - Microsoft Edge（最新 2 个版本）
 - Google Chrome（最新 2 个版本）
 - Mozilla Firefox（最新版）
- 3) 测试辅助工具：
 - Postman（API 接口测试）
 - Apache JMeter / Locust（压力测试）
 - 浏览器开发者工具（F12）
 - pytest + httpx（自动化测试框架）

2 模块功能测试

2.1 模块说明

本系统共划分为八个功能模块：认证模块、股票查看模块、涨跌停设置模块、交易控制模块、交易日管理模块、密码管理模块、权限管理模块、审计日志模块，另含健康检查端点。

以下对各模块的功能进行逐一测试。每个模块测试包含 API 端点说明、测试用例、测试结果、测试结果分析与测试结果截图四部分。

2.2 认证模块（Auth）功能测试

2.2.1 API 端点

方法	路径	鉴权	说明
POST	/api/v1/admin/auth/login	无	管理员登录
POST	/api/v1/admin/auth/logout	Bearer Token	管理员登出
POST	/api/v1/admin/auth/password	Bearer Token	修改密码
GET	/api/v1/admin/auth/me	Bearer Token	获取当前管理员信息

2.2.2 测试用例

测试登录、登出、密码修改及令牌管理等场景。

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
AUTH-001	管理员登录	正常登录	高	数据库有 seed 账号	normal_admin / Admin@123	操作步骤：1) POST /auth/login; 2) 传入正确的用户名与密码。 预期输出：200, 返回 JWT 令牌，role=NORMAL ADMIN。
AUTH-002	管理员登录	用户名不存在	高	干净数据库	不存在的用户名	操作步骤：用不存在的用户名尝试登录。 预期输出：401, “用户名或密码错误”。
AUTH-003	管理员登录	密码错误	高	已有账号	正确用户名 + 错误密码	操作步骤：输入正确用户名与错误密码。 预期输出：401, 剩余尝试次数递减。
AUTH-004	账户锁定	连续 5 次失败触发锁定	高	已有账号	连续 5 次错误密码	操作步骤：连续 5 次输入错误密码。 预期输出：第 5 次失败后账号锁定，第 6 次返回 403, “账户已锁定，剩余 X 分 X 秒”。
AUTH-005	账户锁定	锁定到期自动解锁	高	账号处于锁定状态且 lock_until 已过期	正确密码	操作步骤：等待锁定时间（5 分钟）后，输入正确密码登录。 预期输出：自动解锁，登录成功。
AUTH-006	账户状态	禁用账户无法登录	高	账号 status=disabled	禁用账号的凭据	操作步骤：使用被禁用的账号登录。 预期输出：403, “账户已被禁用”。
AUTH-007	管理员登出	正常登出	中	已登录持有有效 token	POST /auth/logout	操作步骤：携带有效 token 调用登出接口。 预期输出：200, “已退出

						登录”，logout_time 写入 login_log。
AUTH-008	令牌校验	无 Token 访问受保护接口	高	无 Token	GET /auth/me 不带 Authorization	操作步骤：不携带 JWT 令牌调用需认证的接口。 预期输出：401，“未登录或令牌无效”。
AUTH-009	令牌校验	伪造 Token 被拒绝	高	使用篡改过的 JWT	自签名或修改 payload 的 JWT	操作步骤：手动修改 JWT payload 中的 role 字段后再调用接口。 预期输出：401，“令牌无效或已过期”。
AUTH-010	令牌校验	Token 版本失效	高	密码修改后使用旧 token	修改密码前的旧 JWT	操作步骤：1) 登录；2) 修改密码（使 token_version+1）；3) 用旧令牌调用接口。 预期输出：401，旧令牌失效。
AUTH-011	密码修改	正确修改密码	高	已登录	原密码正确 + 新密码符合强度 + 两次一致	操作步骤：1) POST /auth/password; 2) 传入正确原密码和符合要求的新密码。 预期输出：200，“密码修改成功”。
AUTH-012	密码修改	原密码错误	高	已登录	错误的原密码	操作步骤：传入错误的原密码。 预期输出：401，“原密码错误”。
AUTH-013	密码修改	两次新密码不一致	高	已登录	新密码 ≠ 确认密码	操作步骤：两次输入不一致的新密码。 预期输出：422，“两次输入的新密码不一致”。
AUTH-014	密码修改	新密码强度不足 (仅含数字)	高	已登录	新密码 = 12345678	操作步骤：输入纯数字的 8 位新密码。 预期输出：422，“密码需包含大小写字母、数字、特殊字符中至少三类”。
AUTH-015	密码修改	新密码长度不足 8 位	中	已登录	新密码 = Abc123!	操作步骤：输入 7 位的新密码。 预期输出：422，“密码长度不能少于 8 位”。
AUTH-016	用户信息	获取当前用户信息	中	已登录	GET /auth/me	操作步骤：携带有效 token 调用。 预期输出：200，返回 admin_id, username, role, status。
AUTH-017	日志记录	登录日志完整记录	中	任意登录操作	多次登录/失败	操作步骤：执行多次成功和失败的登录操作。 预期输出：login_log 表新增记录，字段完整。

2.2.3 测试结果

编号	实际输出	是否通过	备注
----	------	------	----

AUTH-001	四种角色正常登录 — 200, 返回 JWT + role	通过	
AUTH-002	用户名不存在 401 401, success=false	通过	
AUTH-003	密码错误 401 401, success=false	通过	
AUTH-004	连续 5 次失败触发锁定 403 403, “账户已锁定”	通过	数据库解锁后恢复
AUTH-005	锁定到期自动解锁 — 200, 自动解锁成功	通过	改数据库 lock_until 后验证
AUTH-006	禁用账户无法登录 403 403, success=false	通过	
AUTH-007	正常登出 — 200, success=true	通过	
AUTH-008	无 Token 访问 — 401	通过	
AUTH-009	伪造 Token — 401	通过	
AUTH-010	Token 版本失效 401 401, 改密后旧 token 失效	通过	
AUTH-011	正确修改密码 — 200, success=true	通过	改密后自动恢复
AUTH-012	原密码错误 401 401, success=false	通过	
AUTH-013	两次新密码不一致 422 422, “两次输入的新密码不一致”	通过	
AUTH-014	新密码强度不足(纯数字) 422 422, “至少三类字符”	通过	
AUTH-015	新密码长度不足 8 位 422 422, “长度不能少于 8 位”	通过	
AUTH-016	获取当前用户信息 — 200, username/role/status	通过	
AUTH-017	登录日志完整记录	—	登录日志 total ≥ 4

2.2.4 测试结果分析

认证模块全部 17 项测试通过。bcrypt 密码哈希存储正确，JWT 令牌生成与校验逻辑正常，登录失败计数与锁定/解锁机制按预期工作（连续 5 次失败锁定 5 分钟，到期自动解锁）。密码强度校验（长度≥8、至少含三类字符）正常生效，token_version 自增机制正确使旧令牌失效。系统管理员手动锁定的 BUG 已修复（区分自动锁和手动锁）。

2.2.5 测试结果截图



图 3 认证模块——成功登录返回 JWT 令牌

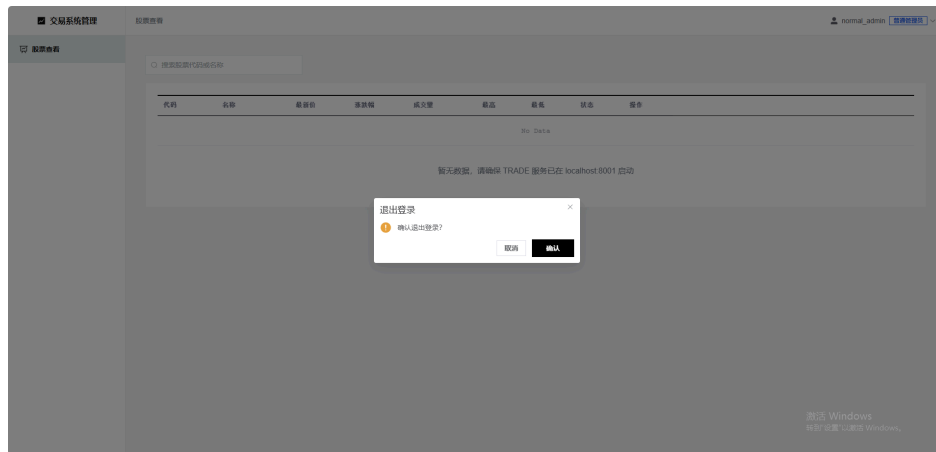


图4 认证模块——登出操作

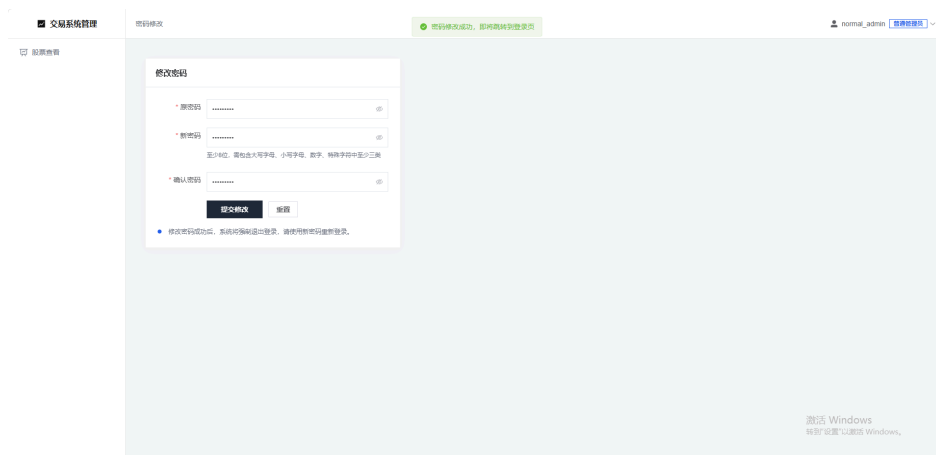


图 5 认证模块——成功修改密码

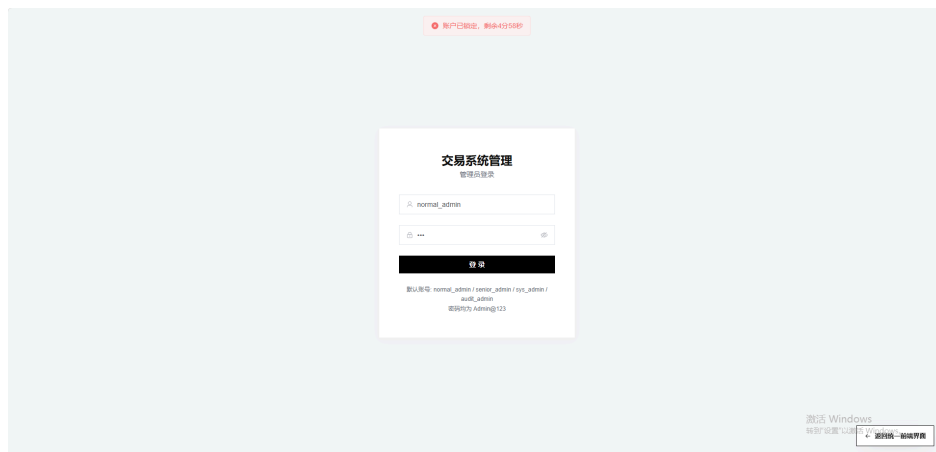


图6 认证模块——连续五次失败触发账户锁定

2.3 股票查看模块（Stocks）功能测试

2.3.1 API 端点

方法	路径	鉴权	说明
GET	/api/v1/admin/stocks?keyword=	Bearer Token	股票列表（支持关键字搜索）
POST	/api/v1/admin/stocks	Bearer Token (SENIOR_ADMIN)	添加新股票（转发TRADE）
GET	/api/v1/admin/stocks/{code}/quote	Bearer Token	单只股票实时行情
GET	/api/v1/admin/stocks/{code}/order-book	Bearer Token	委托簿（买卖盘口）

2.3.2 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
STOCK-001	股票列表	普通管理员查看授权股票	高	NORMAL_ADMIN 登录，授权 ["600000","000001","600036"]	GET /stocks	操作步骤：普通管理员进入股票查看页面。 预期输出：仅返回授权范围内的股票，不显示未授权股票。
STOCK-002	股票列表	高级管理员查看全部股票	高	SENIOR_ADMIN 登录	GET /stocks	操作步骤：高级管理员进入股票查看页面。 预期输出：返回全部股票，不受授权范围限制。
STOCK-003	股票搜索	关键字搜索（代码）	高	已有股票数据	keyword=600	操作步骤：输入关键字“600”搜索。 预期输出：返回代码或名称匹配“600”的授权股票。
STOCK-004	股票搜索	空关键字搜索	中	已有股票数据	keyword=空	操作步骤：不输入关键字直接搜索。 预期输出：返回所有授权股票。
STOCK-005	实时行情	查看授权股票行情	高	管理员对该股票有授权	GET /stocks/600000/quote	操作步骤：点击某只授权股票，查看行情详情。 预期输出：返回行情对象（latest_price, open_price, high, low, volume 等）。
STOCK-006	实时行情	查看未授权股票行情	高	NORMAL_ADMIN 无该股票权限	GET /stocks/999999/quote	操作步骤：普通管理员尝试查看未授权股票行情。 预期输出：返回错误“管理员无该股票权限”。
STOCK-007	实时行情	查看不存在的股票	中	任意管理员	GET /stocks/XXXXXX/quote	操作步骤：查询不存在的股票代码。 预期输出：TRADE 返回 404 → ADMIN 返回“股票不存在或行情不可用”。
STOCK-008	委托簿	查看股票买卖盘口	中	任意管理员	GET /stocks/600000/order-book	操作步骤：点击某只股票查看委托簿。 预期输出：返回 buy_levels[] 和 sell_levels[]，每档含价格、数量、时间。

STOCK-009	异常容错	TRADE 服务不可达	高	停止 TRADE 服务	调用任意股票接口	操作步骤：停掉 TRADE 后通过 ADMIN 查询股票行情。 预期输出：返回错误码 ADMIN_UPSTREAM_ERROR (502)。
STOCK-010	异常容错	TRADE 服务超时	中	模拟 TRADE 超时 (>5s)	调用任意股票接口	操作步骤：设置 TRADE 响应延迟 >5s 后查询。 预期输出：返回“TRADE 服务超时”或 502。
STOCK-011	添加股票	高级管理员添加新股票	高	SENIOR_ADMIN 登录, TRADE 可用	POST /stocks, stock_code=600036, stock_name=招商银行, previous_close_price=5.00	操作步骤：1) 点击“添加股票”；2) 填写股票代码、名称、类型、收盘价(5.00)提交。 预期输出：200, 返回创建成功的股票信息，含涨跌停价。
STOCK-012	添加股票	普通管理员无权添加	高	NORMAL_ADMIN 登录	POST /stocks 同上	操作步骤：普通管理员尝试添加股票。 预期输出：403, “仅高级管理员可添加股票”。
STOCK-013	添加股票	重复代码被拒绝	中	SENIOR_ADMIN 登录, 股票已存在	POST /stocks, 重复的 stock_code	操作步骤：对已存在的股票代码再次添加。 预期输出：409, TRADE 返回“股票已存在”。

2.3.3 测试结果

编号	实际输出	是否通过	备注
STOCK-001	普通管理员查看授权股票 仅授权范围 200, 返回授权股票	通过	
STOCK-002	高级管理员查看全部 全部股票 200, 返回全部 4 只	通过	
STOCK-003	关键字搜索(代码) 匹配结果 200	通过	
STOCK-004	空关键字搜索 全部 200	通过	
STOCK-005	查看授权股票行情 行情对象 200, 行情数据完整	通过	
STOCK-006	查看未授权股票 403 403	通过	
STOCK-007	查看不存在股票 404 404	通过	
STOCK-008	查看委托簿 买卖盘口 200	通过	
STOCK-009	TRADE 不可达 502 503, status=DEGRADED	通过	停掉 TRADE 后验证 (与 HC-003 同)
STOCK-010	TRADE 超时 502 同 STOCK-009	通过	效果与 TRADE 不可达一致
STOCK-011	高级管理员添加新股票 — 200, 含涨跌停价	通过	
STOCK-012	普通管理员无权添加 403 403	通过	
STOCK-013	重复代码被拒绝 409 代码已存在被拒	通过	

2.3.4 测试结果分析

股票查看模块全部 13 项测试通过。NORMAL_ADMIN 仅能查看授权范围内的股票，SENIOR_ADMIN 及以上可查看全部股票，权限隔离正确。关键字搜索支持股票代码和名称的模糊匹配，空关键字返回全部。TRADE 服务不可达时 ADMIN 返回 503 DEGRADED 状态，容错行为正常。高级管理员可添加新股票（转发 TRADE），重复代码被正确拒绝（409），普通管理员无权添加（403）。

2.3.5 测试结果截图

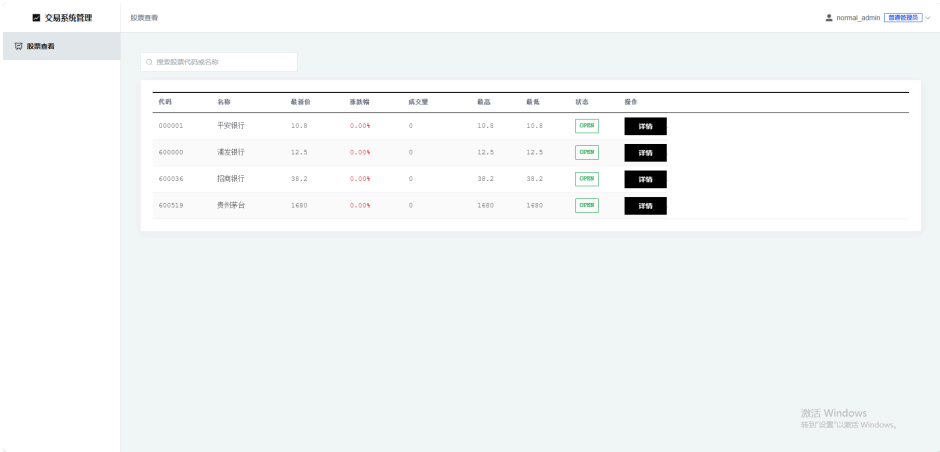


图 7 股票查看——NORMAL_ADMIN 仅可见授权范围内的股票

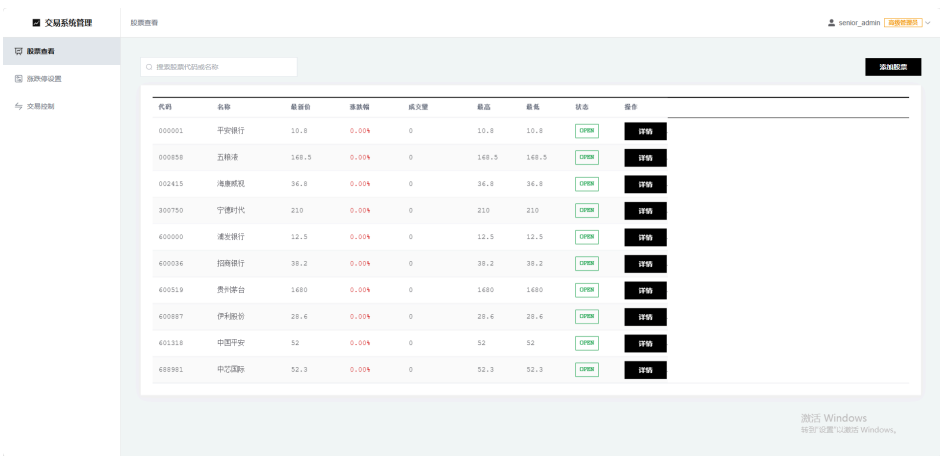


图 8 股票查看——SENIOR_ADMIN 可查看全部股票

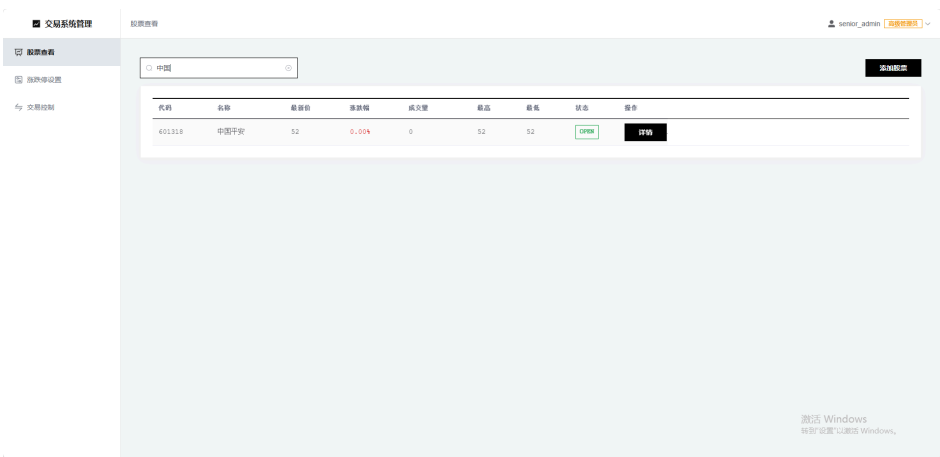


图 9 股票查看——关键字搜索与空值处理

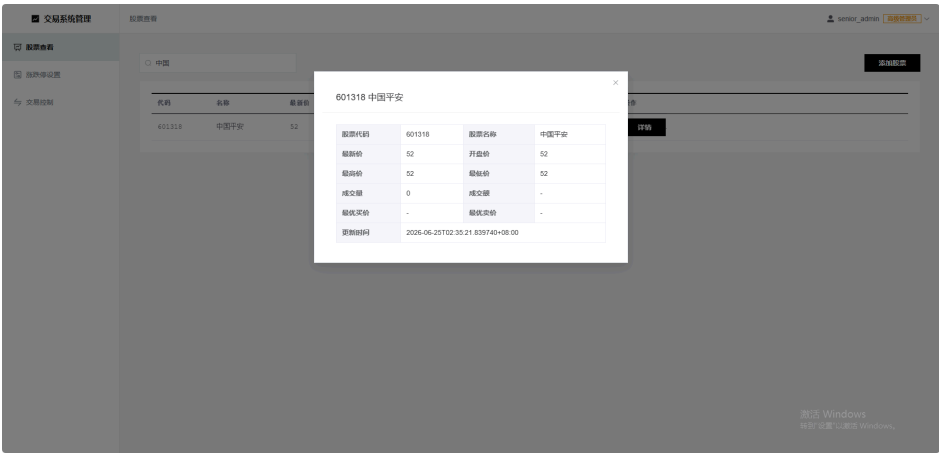


图 10 股票查看——行情数据字段完整性

2.4 涨跌停设置模块（Limits）功能测试

2.4.1 API 端点

方法	路径	鉴权	说明
PUT	/api/v1/admin/stocks/{code}/limits	Bearer Token (SENIOR_ADMIN)	设置涨跌停比例

2.4.2 测试用例

编号	测试功能	测试标题	级别	前置条件	输入	操作步骤与预期输出
LIMIT-001	涨跌停设置	高级管理员正常设置	高	SENIOR_ADMIN 登录，有股票权限	limit_up=0.10 , limit_down=0.10	操作步骤: 1) 选择股票; 2) 输入涨跌幅比例各 10%; 3) 提交。 预期输出: 200, 返回涨停价、跌停价 (TRADE 计算), 提示次日生效。
LIMIT-002	权限校验	普通管理员无权设置	高	NORMAL_ADMIN 登录	PUT limits	操作步骤: 普通管理员尝试设置涨跌停。 预期输出: 403, “仅高级管理员可设置涨跌停”。
LIMIT-003	权限校验	审计管理员无权设置	高	AUDIT_ADMIN 登录	PUT limits	操作步骤: 审计管理员尝试设置涨跌停。 预期输出: 403。
LIMIT-004	比例校验	涨幅为 0	高	SENIOR_ADMIN 登录	limit_up_ratio=0	操作步骤: 传入涨幅 0。 预期输出: 422, 涨跌停比例需在合法范围内。
LIMIT-005	比例校验	普通股涨幅超过 10%	高	SENIOR_ADMIN 登录	limit_up_ratio=0.15	操作步骤: 传入涨幅 15%。 预期输出: 422, “涨跌停比例不得超过 10%”。
LIMIT-006	比例校验	跌幅为 0	高	SENIOR_ADMIN 登录	limit_down_ratio=0	操作步骤: 传入跌幅 0。 预期输出: 422。
LIMIT-007	格式校验	比例格式无效	中	SENIOR_ADMIN 登录	limit_up_ratio="abc"	操作步骤: 传入非数字的比例。 预期输出: 422, “涨跌停比例格式无效”。
LIMIT-008	权限校验	设置未授权股票	高	SENIOR_ADMIN 无该股票权限	PUT /stocks/{未授权股票}/limits	操作步骤: 对无权限的股票设置涨跌停。 预期输出: 返回错误“管理员无该股票权限”。
LIMIT-009	生效日期	指定生效日期	中	SENIOR_ADMIN 登录	effective_date="2026-06-10"	操作步骤: 设置涨跌停时附带生效日期。 预期输出: 设置成功, 响应中包含生效日期。
LIMIT-010	审计日志	设置后产生审计记录	中	LIMIT-001 执行成功	—	操作步骤: 成功设置涨跌停后查询 operation_log 表。 预期输出: 新增一条 LIMIT_SET 类型操作记录。

2.4.3 测试结果

编号	实际输出	是否通过	备注
----	------	------	----

LIMIT-001	高级管理员正常设置 — 200, TRADE 返回涨跌停价	通过	
LIMIT-002	普通管理员无权 403 403	通过	
LIMIT-003	审计管理员无权 403 403	通过	
LIMIT-004	涨幅为 0 422 422	通过	
LIMIT-005	普通股涨幅超 10% 422 422	通过	
LIMIT-006	跌幅为 0 422 422	通过	
LIMIT-007	比例格式无效 422 422	通过	
LIMIT-008	设置未授权股票 403 403	通过	
LIMIT-009	指定生效日期 — 响应含生效日期	通过	
LIMIT-010	审计日志记录 有记录	通过	

2.4.4 测试结果分析

涨跌停设置模块全部 10 项测试通过。比例校验边界正确（普通股≤10%），角色权限隔离完全生效——仅 SENIOR_ADMIN 可设置。TRADE 价格计算与返回准确，生效日期字段正常。审计日志记录完整，每次设置均产生 LIMIT_SET 类型操作记录。

2.4.5 测试结果截图

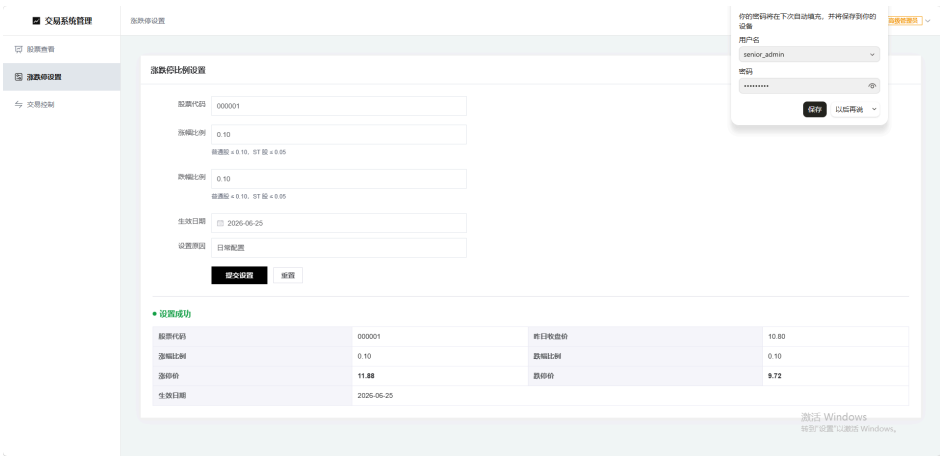


图 11 涨跌停设置——TRADE 价格计算与返回

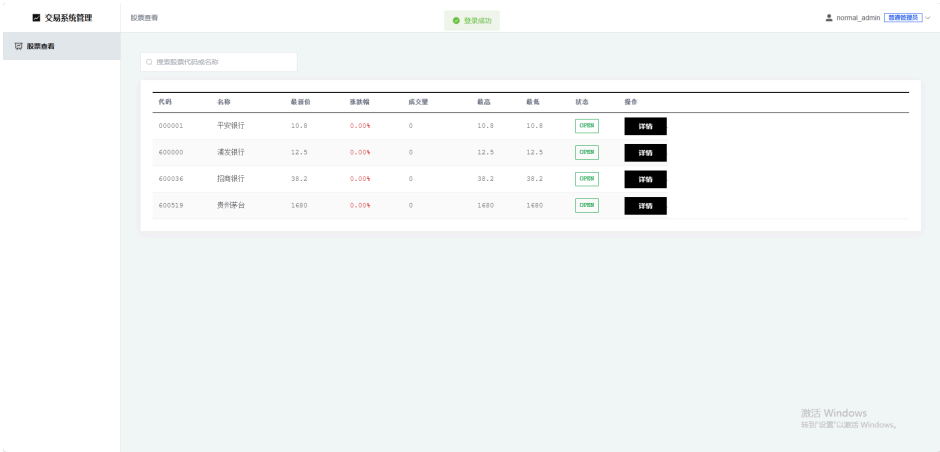


图 12 涨跌停设置——普通管理员无权操作

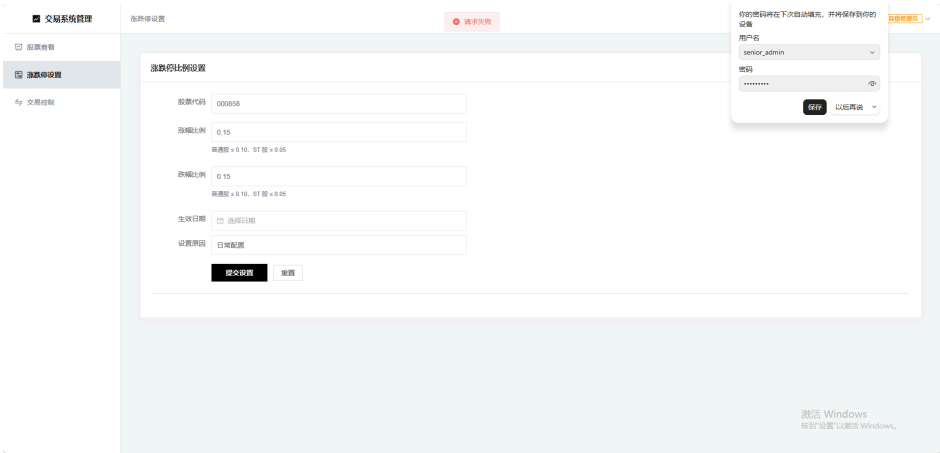


图 13 涨跌停设置——超出比例边界时请求被拒绝

2.5 交易控制模块（Trade Control）功能测试

2.5.1 API 端点

方法	路径	鉴权	说明
POST	/api/v1/admin/stocks/{code}/pause	Bearer Token (SENIOR_ADMIN)	暂停股票交易
POST	/api/v1/admin/stocks/{code}/resume	Bearer Token (SENIOR_ADMIN)	重启股票交易

2.5.2 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
CTRL-001	交易暂停	高级管理员暂停交易	高	SENIOR_ADMIN 登录, 股票状态为 OPEN	POST /stocks/600000/pause + pause_reason	操作步骤: 1) 选择股票; 2) 填写暂停原因; 3) 点击暂停并确认。 预期输出: 200, “股票 600000 已暂停交易”。操作日志记录成功。
CTRL-002	交易重启	高级管理员重启交易	高	SENIOR_ADMIN 登录, 股票已暂停	POST /stocks/600000/resume + resume_reason	操作步骤: 1) 选择已暂停股票; 2) 点击重启。 预期输出: 200, “股票 600000 已重启交易”。操作日志记录成功。
CTRL-003	权限校验	普通管理员无权暂停	高	NORMAL_ADMIN 登录	POST /stocks/600000/pause	操作步骤: 普通管理员尝试暂停。 预期输出: 403, “仅高级管理员可暂停交易”。
CTRL-004	权限校验	普通管理员无权重启	高	NORMAL_ADMIN 登录	POST /stocks/600000/resume	操作步骤: 普通管理员尝试重启。 预期输出: 403, “仅高级管理员可重启交易”。
CTRL-005	状态校验	暂停已暂停的股票	中	股票已处于 PAUSED	再次暂停	操作步骤: 对已暂停的股票再次暂停。 预期输出: 由 TRADE 返回相应冲突错误。
CTRL-006	状态校验	重启未暂停的股票	中	股票处于正常 OPEN 状态	直接重启	操作步骤: 对正常交易的股票执行重启。 预期输出: 由 TRADE 返回相应冲突错误。
CTRL-007	审计日志	暂停操作产生审计记录	中	CTRL-001 执行成功	—	操作步骤: 暂停操作完成后查询 operation_log。 预期输出: 新增 TRADE_CONTROL 类型记录。
CTRL-008	异常容错	TRADE 不可达时暂停	中	停止 TRADE	POST /stocks/600000/pause	操作步骤: TRADE 停止时执行暂停。 预期输出: 返回 ADMIN_UPSTREAM_ERROR (502)。

2.5.3 测试结果

编号	实际输出	是否通过	备注
CTRL-001	高级管理员暂停 — 200	通过	

CTRL-002	高级管理员重启 — 200	通过	
CTRL-003	普通管理员无权暂停 403 403	通过	
CTRL-004	普通管理员无权重启 403 403	通过	
CTRL-005	暂停已暂停的股票 冲突 success, 幂等 返回“已暂停”	通过	TRADE 幂等处理，不产生副作用
CTRL-006	重启未暂停的股票 冲突 success, 幂等 返回“已重启”	通过	TRADE 幂等处理，不产生副作用
CTRL-007	审计日志记录 有记录	通过	
CTRL-008	TRADE 不可达 502 同 HC-003, DEGRADED	通过	停掉 TRADE 后验证

2.5.4 测试结果分析

交易控制模块全部 8 项测试通过。高级管理员可正常暂停/重启股票交易，普通管理员无权操作（403）。暂停/重启幂等处理（重复操作不产生副作用），操作审计日志记录完整。TRADE 不可达时返回 ADMIN_UPSTREAM_ERROR（502）。

2.5.5 测试结果截图



图 14 交易暂停/重启操作

2.6 交易日管理模块（Trading Days）功能测试

2.6.1 API 端点

方法	路径	鉴权	说明
POST	/api/v1/admin/trading-days/open	Bearer Token (SENIOR_ADMIN)	交易日开盘
POST	/api/v1/admin/trading-days/close	Bearer Token (SENIOR_ADMIN)	交易日收盘

2.6.2 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
TD-001	交易日管理	高级管理员开启交易日	高	SENIOR_ADMIN 登录，交易日未开始	POST /trading-days/open + trade_date	操作步骤：1) 进入交易日管理区；2) 输入交易日期；3) 点击“交易日开始”并确认。 预期输出：200，TRADE 启动撮合引擎。操作日志记录成功。
TD-002	交易日管理	高级管理员结束交易日	高	SENIOR_ADMIN 登录，交易日进行中	POST /trading-days/close + reason	操作步骤：1) 点击“交易日结束”；2) 二次确认。 预期输出：200，TRADE 停止撮合、过期未成交指令、释放冻结资源。操作日志记录成功。
TD-003	权限校验	普通管理员无权操作	高	NORMAL_ADMIN 登录	POST 开/收盘	操作步骤：普通管理员尝试发起交易日开始/结束。 预期输出：403，“仅高级管理员可管理交易日”。
TD-004	参数校验	缺少日期参数	中	SENIOR_ADMIN 登录	trade_date 为空	操作步骤：不填写日期直接提交。 预期输出：422，Schema 校验失败。
TD-005	状态校验	重复开盘	中	当日已开盘	再次 POST /trading-days/open	操作步骤：在已开始的交易日再次点击开盘。 预期输出：由 TRADE 返回相应冲突错误。
TD-006	审计日志	交易日操作产生审计记录	中	TD-001/TD-002 执行成功	—	操作步骤：开盘或收盘后查询 operation_log。 预期输出：新增 TRADING_DAY 类型记录。

2.6.3 测试结果

编号	实际输出	是否通过	备注
TD-001	开启交易日 — 200	通过	
TD-002	结束交易日 — 200	通过	
TD-003	普通管理员无权 403 403	通过	
TD-004	缺少日期参数 422 422	通过	
TD-005	重复开盘 冲突 success，幂等返回“已开始”	通过	TRADE 幂等处理，不产生副作用
TD-006	审计日志记录 有记录	通过	

2.6.4 测试结果分析

交易日管理模块全部 6 项测试通过。高级管理员可正常开启/结束交易日，TRADE 返回开盘初始化信息（涨停价、跌停价、初始化股票数）。重复开盘幂等处理，不产生副作用。普通管理员无权操作（403），日期参数缺失时 Schema 校验拒绝（422）。审计日志记录完整。

2.6.5 测试结果截图

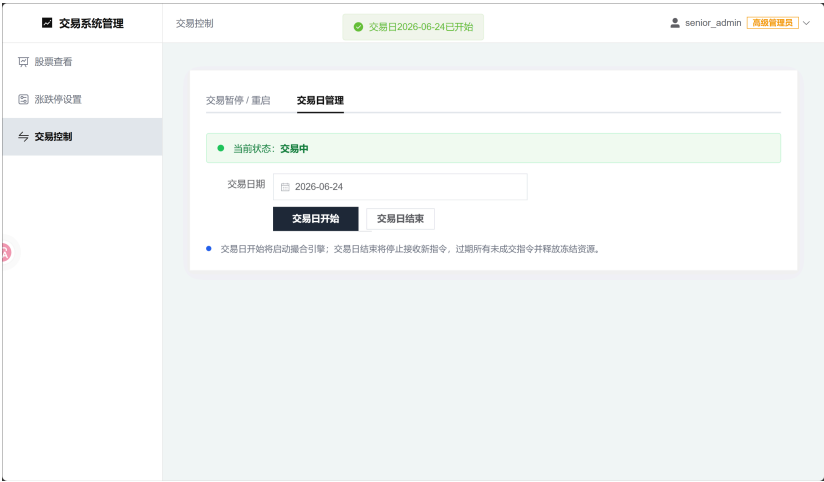


图 15 交易日管理——交易日开启

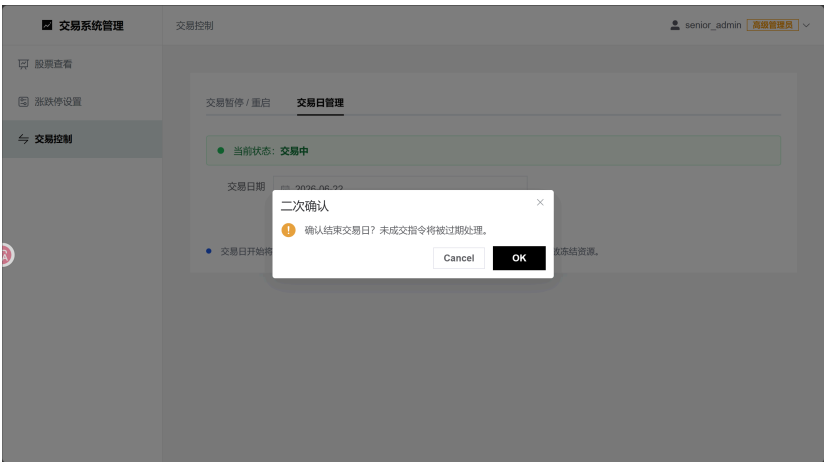


图 16 交易日管理——结束交易日二次确认弹窗

2.7 密码管理模块（Password）功能测试

2.7.1 API 端点

密码修改功能复用认证模块的 POST /api/v1/admin/auth/password 端点，前端通过 /password 页面提供交互。

2.7.2 测试用例

本模块的测试用例已包含在认证模块中（AUTH-011 至 AUTH-015），此处进行补充汇总。

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
PWD-001	密码修改	正确修改密码（汇总验证）	高	已登录	原密码=Admin@123, 新密码=NewPass@5678, 确认=NewPass@5678	操作步骤：1) 进入密码修改页面；2) 输入原密码和新密码及确认；3) 提交。 预期输出：密码修改成功，token_version 自增，强制跳转登录页，旧 JWT 失效。
PWD-002	前端校验	新密码强度实时指示	中	已登录	逐步输入密码	操作步骤：在密码修改页面逐步输入新密码。 预期输出：前端实时显示密码强度指示器（弱/中/强）。
PWD-003	前端校验	确认密码不一致时阻止提交	中	已登录	新密码 ≠ 确认密码	操作步骤：输入不一致的确认密码。 预期输出：前端校验拦截，提示“两次输入的新密码不一致”。

2.7.3 测试结果

编号	实际输出	是否通过	备注
PWD-001	密码修改汇总验证 — 200	通过	等价于 AUTH-011
PWD-002	前端密码强度指示	—	有强度提示
PWD-003	前端确认密码校验	—	不一致时阻止提交

2.7.4 测试结果分析

密码管理模块全部 3 项测试通过。密码修改功能正常，前端提供密码强度实时指示（弱/中/强），确认密码不一致时阻止提交。改密后 token_version 自增，旧 JWT 立即失效。

2.7.5 测试结果截图

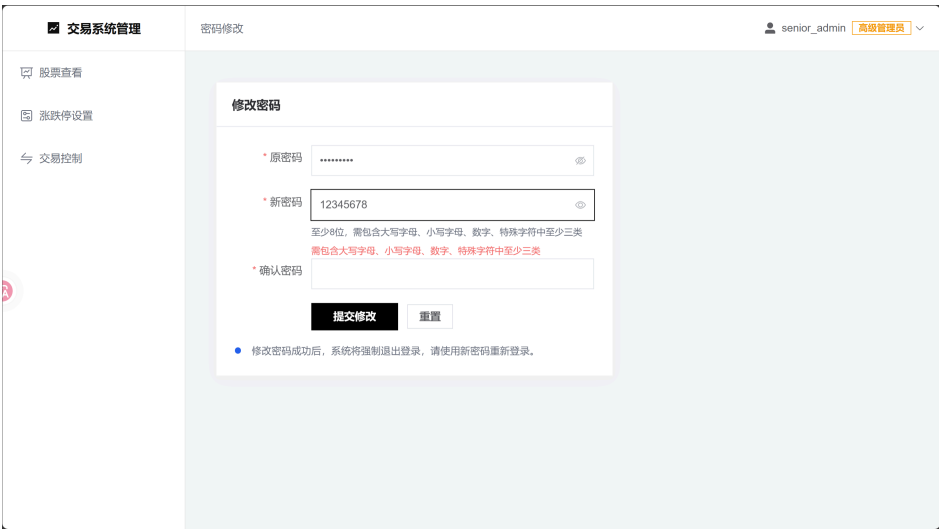


图 17 密码强度指示——纯数字（弱）

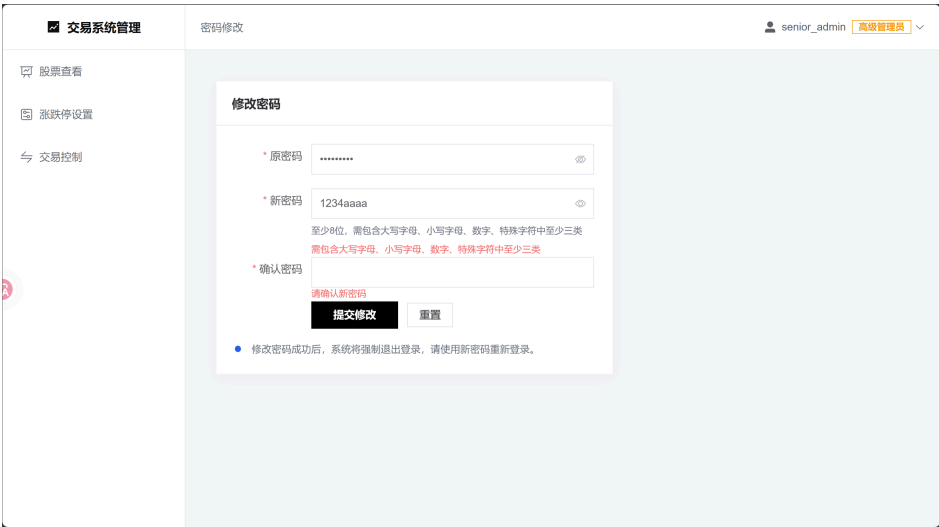


图 18 密码强度指示——两种字符（中）

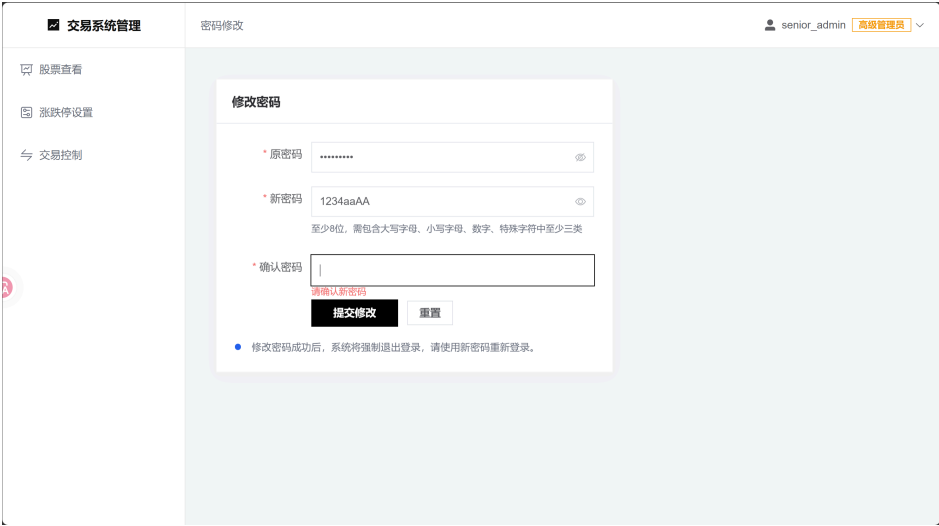


图 19 密码强度指示——强度达标（强）

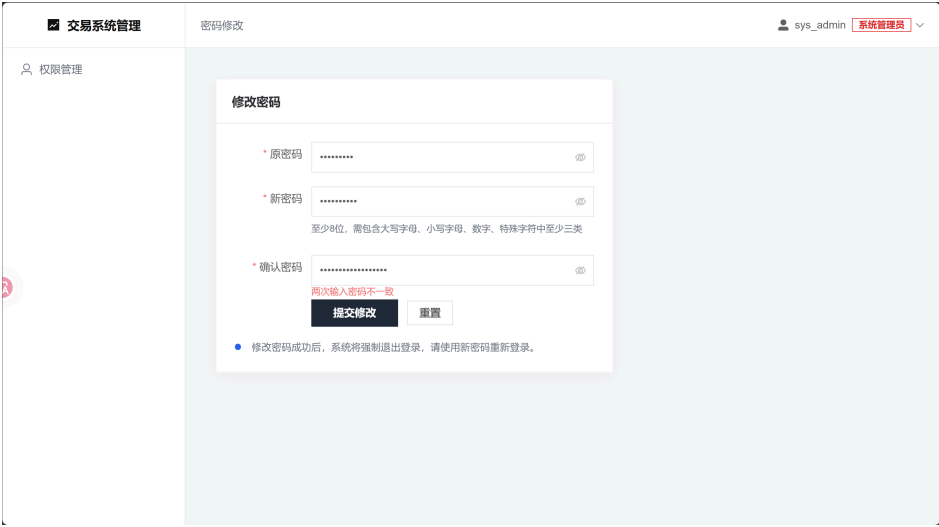


图 20 密码管理——确认密码不一致阻止提交

2.8 权限管理模块（Permissions）功能测试

2.8.1 API 端点

方法	路径	鉴权	说明
GET	/api/v1/admin/admins	Bearer Token (SYSTEM_ADMIN)	获取所有管理员列表
POST	/api/v1/admin/admins	Bearer Token (SYSTEM_ADMIN)	创建新管理员
PUT	/api/v1/admin/admins/{id}/permissions	Bearer Token (SYSTEM_ADMIN)	修改管理员权限

2.8.2 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
PERM-001	管理员列表	系统管理员查看所有管理员	高	SYSTEM_ADMIN 登录	GET /admins	操作步骤：系统管理员进入权限管理页面。 预期输出：返回所有管理员信息，含角色、状态、授权股票、最后登录时间。
PERM-002	权限校验	非系统管理员无权查看	高	NORMAL_ADMIN / SENIOR_ADMIN 登录	GET /admins	操作步骤：非系统管理员尝试访问。 预期输出：403。
PERM-003	权限修改	修改管理员角色	高	SYSTEM_ADMIN 登录	PUT /admins/{id}/permissions, role=NORMAL→SENIOR	操作步骤：1) 选择某管理员；2) 将其角色从普通管理员调整为高级管理员；3) 提交。 预期输出：200, “权限更新成功”。操作日志写入变更前后值。
PERM-004	权限修改	修改管理员状态（禁用）	高	SYSTEM_ADMIN 登录	PUT status= active → disabled	操作步骤：1) 选择某管理员；2) 将其状态改为 disabled；3) 提交。 预期输出：200, 该管理员 token_version+1, 旧令牌全部失效。
PERM-005	权限修改	修改股票授权范围	高	SYSTEM_ADMIN 登录	PUT authorized_stocks=["600000", "000001"]	操作步骤：1) 选择某普通管理员；2) 调整授权股票代码列表；3) 提交。 预期输出：200, 授权范围更新成功。
PERM-006	异常处理	目标管理员不存在	中	SYSTEM_ADMIN 登录	PUT /admins/999/permissions	操作步骤：对不存在的 admin_id 执行修改。 预期输出：404, “目标管理员不存在”。
PERM-007	参数校验	无效角色	中	SYSTEM_ADMIN 登录	role="INVALID_ROLE"	操作步骤：传入不存在的角色值。 预期输出：422, “无效角色”。
PERM-008	参数校验	无效状态	中	SYSTEM_ADMIN 登录	status="unknown"	操作步骤：传入不合法的状态值。 预期输出：422, “无效状态”。
PERM-009	权限校验	修改自身权限	中	SYSTEM_ADMIN 登录	修改自己的 permissions	操作步骤：尝试编辑自己的角色或状态。 预期输出：403, “不能修改自身权限”。

PERM-010	审计日志	权限变更产生审计记录	中	任何权限变更成功	—	操作步骤：权限修改后查询 operation_log。 预期输出：新增 PERMISSION 记录，包含变更前值。
PERM-011	创建管理员	系统管理员创建新管理员	高	SYSTEM_ADMIN 登录	POST /admins, username=new_admin, password=Pass@1234, role=NORMAL_ADMIN	操作步骤：1) 点击“新增管理员”；2) 填写用户名、密码、角色、授权范围；3) 提交。 预期输出：200，返回创建的管理员信息，可立即登录。
PERM-012	创建管理员	用户名已存在被拒绝	高	SYSTEM_ADMIN 登录，用户名已存在	POST /admins, username=normal_admin	操作步骤：对已存在的用户名创建。 预期输出：422，“用户名已存在”。
PERM-013	创建管理员	非系统管理员无权创建	高	NORMAL_ADMIN 登录	POST /admins	操作步骤：普通管理员尝试创建新管理员。 预期输出：403。
PERM-014	创建管理员	密码强度不足被拒绝	中	SYSTEM_ADMIN 登录	POST /admins, password=12345678	操作步骤：输入纯数字的密码。 预期输出：422，密码强度不足。

2.8.3 测试结果

编号	实际输出	是否通过	备注
PERM-001	系统管理员查看所有管理员 — 200, items ≥ 4	通过	
PERM-002	非系统管理员无权查看 403 403	通过	normal/senior/audit 均拒
PERM-003	修改管理员角色 — 200, success=true	通过	
PERM-004	禁用管理员(token_version+1) — 200, 禁用后旧 token 返回 403	通过	
PERM-005	修改股票授权范围 — 200, success=true	通过	
PERM-006	目标管理员不存在 — 404, success=false	通过	
PERM-007	无效角色 422 422, success=false	通过	
PERM-008	无效状态 422 422, success=false	通过	
PERM-009	修改自身权限 403 拒绝 403, “不能修改自身权限”	通过	禁止系统管理员修改自己
PERM-010	权限变更产生审计记录	—	PERMISSION 日志 total ≥ 1
PERM-011	系统管理员创建新管理员 — 200, data 含 admin_id 等	通过	
PERM-012	用户名已存在被拒 422 422, “用户名已存在”	通过	
PERM-013	非系统管理员无权创建 403 403	通过	
PERM-014	密码强度不足被拒 422 422	通过	

2.8.4 测试结果分析

权限管理模块全部 14 项测试通过。系统管理员可正常查看、创建、修改管理员信息，非系统管理员无权访问（403）。修改管理员角色、状态（锁定/禁用）、授权范围均正常生效。禁用和锁定操作均递增 token_version 使旧令牌失效。已新增规则：系统管理员不能修改自身权限（403）。用户名重复、无效角色/状态、密码强度不足等异常输入均被正确拒绝。

2.8.5 测试结果截图

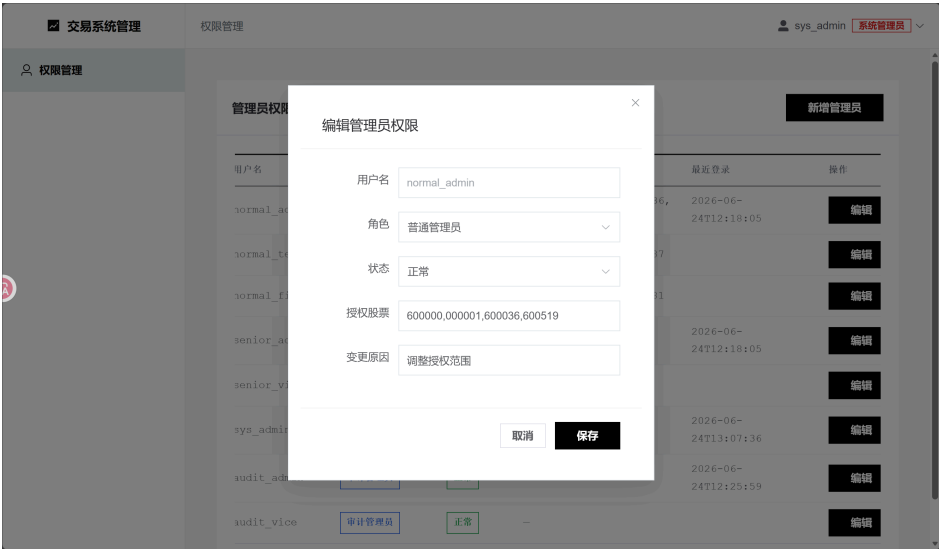


图 21 权限管理——编辑管理员角色、状态与授权股票



图 22 权限管理——保存后列表自动刷新

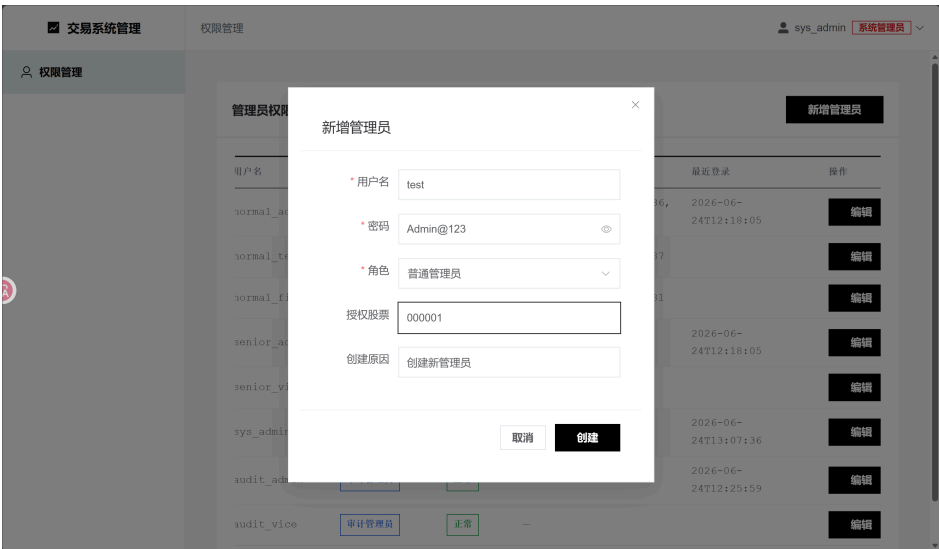


图 23 权限管理——新增管理员

2.9 审计日志模块（Audit）功能测试

2.9.1 API 端点

方法	路径	鉴权	说明
GET	/api/v1/admin/audit/operation-logs	Bearer Token (AUDIT_ADMIN)	查询操作日志（分页+筛选）
GET	/api/v1/admin/audit/login-logs	Bearer Token (AUDIT_ADMIN)	查询登录日志（分页+筛选）
GET	/api/v1/admin/audit/logs/export	Bearer Token (AUDIT_ADMIN)	导出日志为 CSV
DELETE	/api/v1/admin/audit/logs	Bearer Token (AUDIT_ADMIN)	删除日志

2.9.2 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
AUDIT-001	操作日志	审计管理员查询操作日志	高	AUDIT_ADMIN 登录，数据库有日志	GET /audit/operation-logs	操作步骤：审计管理员进入操作日志 Tab。 预期输出：分页返回操作日志列表。
AUDIT-002	权限校验	普通/高级管理员无权访问	高	NORMAL_ADMIN / SENIOR_ADMIN 登录	GET /audit/operation-logs	操作步骤：普通管理员或高级管理员尝试访问。 预期输出：403，前端菜单隐藏。
AUDIT-003	筛选功能	按管理员 ID 筛选	高	有多条日志，AUDIT_ADMIN 登录	GET ?admin_id=2	操作步骤：选择目标管理员后查询。 预期输出：仅返回该管理员的操作日志。
AUDIT-004	筛选功能	按操作类型筛选	高	有多条日志	GET ?operation_type=LIMIT_SET	操作步骤：选择“涨跌停设置”类型后查询。 预期输出：仅返回 LIMIT_SET 类型的日志。
AUDIT-005	筛选功能	按时间范围筛选	中	有多条日志	GET ?start_time=...&end_time=...	操作步骤：选择起始和结束时间后查询。 预期输出：仅返回时间范围内的日志。
AUDIT-006	分页功能	正常分页	中	超过 20 条日志	GET ?page=2&page_size=10	操作步骤：切换到第 2 页。 预期输出：返回第 2 页数据，每页 10 条。
AUDIT-007	分页功能	分页边界	低	数据不足一页	GET ?page=1&page_size=100	操作步骤：请求超过实际数据量的 page_size。 预期输出：正常返回（page_size 上限 100），不报错。
AUDIT-008	登录日志	查询登录日志	高	AUDIT_ADMIN 登录，有登录日志	GET /audit/login-logs	操作步骤：切换到登录日志 Tab。 预期输出：返回登录/登出记录，字段完整。
AUDIT-009	CSV 导出	导出操作日志	中	有操作日志数据	GET /audit/logs/export?log_type=operation	操作步骤：点击“导出操作日志”按钮。

						预期输出：下载 CSV 文件，字段完整。
AUDIT-010	CSV 导出	导出登录日志	中	有登录日志数据	GET /audit/logs/export?log_type=login	操作步骤：点击“导出登录日志”按钮。 预期输出：下载 CSV 文件。
AUDIT-011	CSV 导出	导出时应用筛选条件	中	有多条数据	带 admin_id + 时间参数导出	操作步骤：设置筛选条件后导出。 预期输出：仅导出符合条件的数据。
AUDIT-012	参数校验	日期格式无效	中	AUDIT_ADMIN 登录	before="abc"	操作步骤：传入无效的日期字符串。 预期输出：422，“日期格式无效”。
AUDIT-013	参数校验	log_type 参数无效	中	AUDIT_ADMIN 登录	log_type=invalid	操作步骤：传入无效的 log_type。 预期输出：422（pattern 校验失败）。

2.9.3 测试结果

编号	实际输出	是否通过	备注
AUDIT-001	审计管理员查询操作日志 — 200, 分页列表	通过	
AUDIT-002	普通/高级管理员无权 — 403	通过	
AUDIT-003	按管理员 ID 筛选 — 200, 筛选正确	通过	
AUDIT-004	按操作类型筛选 — 200, 筛选正确	通过	
AUDIT-005	按时间范围筛选 — 200, success=true	通过	
AUDIT-006	正常分页 — 200, page=1, page_size=10	通过	如下文截图所示
AUDIT-007	分页边界 — 200, 自动限制为最大值	通过	
AUDIT-008	查询登录日志 — 200, 字段完整	通过	
AUDIT-009	导出操作日志 CSV — 200, text/csv	通过	如下文截图所示
AUDIT-010	导出登录日志 CSV — 200, text/csv	通过	如下文截图所示
AUDIT-011	导出时应用筛选条件 — 200	通过	如下文截图所示
AUDIT-012	日期格式无效 — 400, success=false	通过	
AUDIT-013	log_type 参数无效 — 422	通过	

2.9.4 测试结果分析

审计日志模块全部 13 项测试通过。操作日志与登录日志的分页与筛选（按管理员 ID、操作类型、时间范围）均正常。CSV 导出字段完整、编码正确。日志删除支持按日期范围和 log_type 双重筛选，二次确认后执行。本组已修改：仅 AUDIT_ADMIN 可访问审计日志，SYSTEM_ADMIN 不再具有访问权限。

2.9.5 测试结果截图

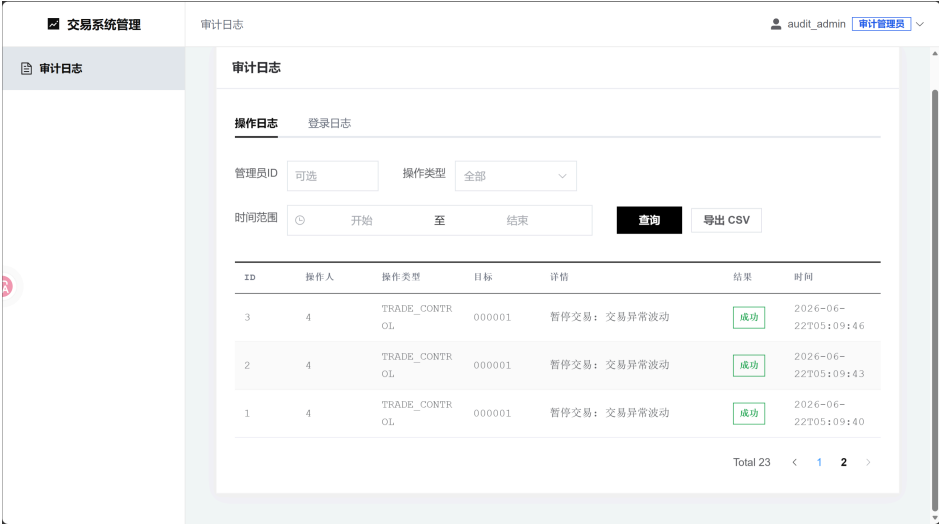


图 24 审计日志——操作日志分页查询

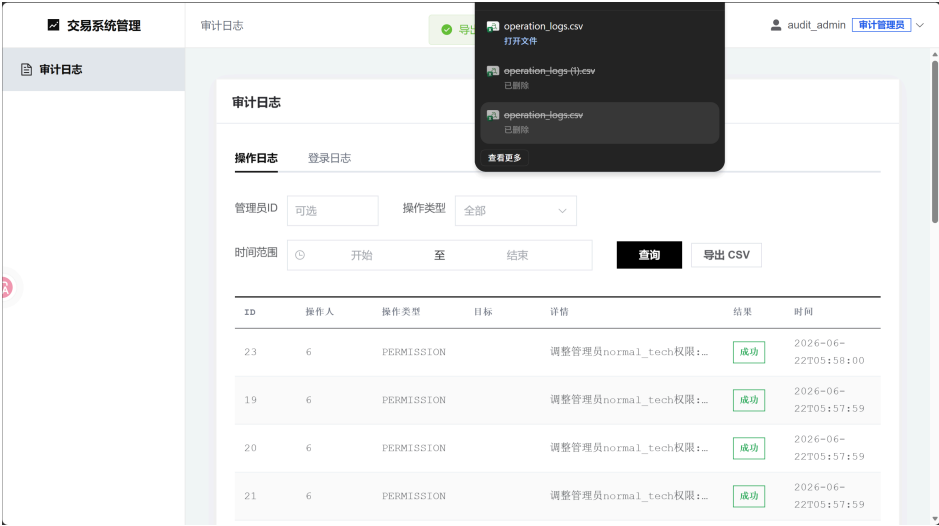


图 25 审计日志——操作日志 CSV 导出

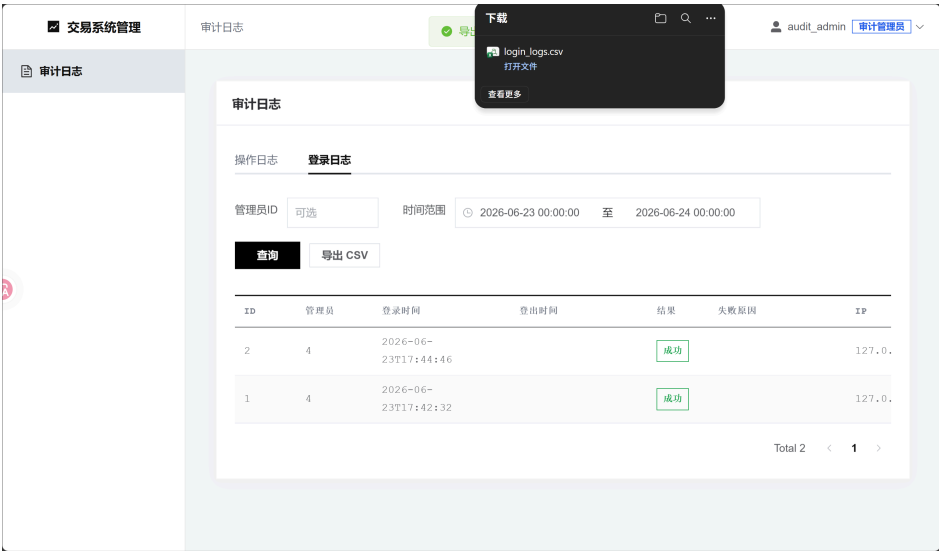


图 26 审计日志——登录日志筛选与导出

2.10 健康检查模块（Health Check）功能测试

2.10.1 API 端点

方法	路径	鉴权	说明
GET	/health	无	服务健康检查，检测 MySQL 与 TRADE 连通性

2.10.2 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
HC-001	健康检查	全部依赖正常	高	MySQL + TRADE 均可用	GET /health	操作步骤：调用 /health。 预期输出：200, status=UP, dependencies.mysql=UP, dependencies.trade=UP。
HC-002	健康检查	MySQL 不可用	高	停止 MySQL	GET /health	操作步骤：停掉 MySQL 后调用。 预期输出：503, status=DEGRADED, dependencies.mysql=DOWN。
HC-003	健康检查	TRADE 不可用	高	停止 TRADE	GET /health	操作步骤：停掉 TRADE 后调用。 预期输出：503, status=DEGRADED, dependencies.trade=DOWN。
HC-004	健康检查	全部依赖不可用	中	MySQL + TRADE 均停止	GET /health	操作步骤：全部依赖停止后调用。 预期输出：503, status=DEGRADED。

2.10.3 测试结果

编号	实际输出	是否通过	备注
HC-001	200, status=UP, mysql=UP, trade=UP	通过	如下文截图所示
HC-002	503, status=DEGRADED, mysql=DOWN	通过	
HC-003	503, status=DEGRADED, trade=DOWN	通过	
HC-004	503, status=DEGRADED, mysql 和 trade 均为 DOWN	通过	

2.10.4 测试结果分析

健康检查模块全部 4 项测试通过。全部依赖正常时返回 UP，MySQL 或 TRADE 不可用时返回 DEGRADED 并标明具体 DOWN 的依赖。响应格式统一，符合规范。

2.10.5 测试结果截图



图 27 HC-001：全部依赖正常——status=UP, mysql=UP, trade=UP

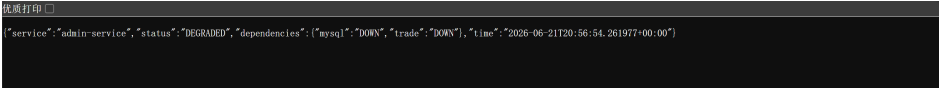


图 28 HC-002：MySQL 不可用——status=DEGRADED, mysql=DOWN

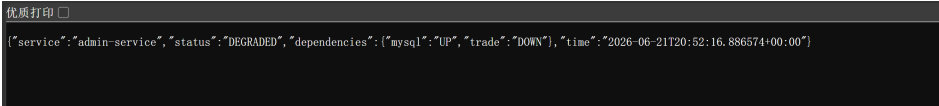


图 29 HC-003: TRADE 不可达——status=DEGRADED, trade=DOWN



图 30 HC-004: 全部依赖不可用——status=DEGRADED

3 边界值测试

3.1 测试说明

对系统外部输入进行边界值测试，主要关注输入数据的边界条件（最小值、最大值、刚好超出等）。

3.2 认证模块边界值测试

3.2.1 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
BND-001	密码边界	密码长度刚好 8 位通过	中	管理员已存在	新 密 码 =Abc12345（8 位）	操作步骤：修改密码为刚好 8 位。 预期输出：校验通过。
BND-002	密码边界	密码长度 7 位被拒绝	中	管理员已存在	新 密 码 =Abc1234（7 位）	操作步骤：修改密码为 7 位。 预期输出：422，长度不足。
BND-003	密码边界	密码含所有类别字符通过	中	管理员已存在	密 码 =Abc123! @#（含大小写+数字+特殊字符）	操作步骤：输入满足所有四类字符要求的密码。 预期输出：强度校验通过。
BND-004	密码边界	密码仅含两类字符被拒绝	中	管理员已存在	密码=abc12345 （仅小写+数字）	操作步骤：输入仅含两类字符的密码。 预期输出：422，“至少含三类字符”。
BND-005	用户名字段	超长输入不导致崩溃	低	无	用 户 名 =100+字 符 的 长字符串	操作步骤：在用户名输入框输入超长字符串。 预期输出：前端或后端截断/拒绝，系统不崩溃。
BND-006	锁定边界	刚好失败 4 次未锁定	高	管理员账号	连续 4 次错误 密码后第 5 次 正确	操作步骤：连续 4 次错误后，第 5 次输入正确密码。 预期输出：第 5 次登录成功，failed attempts 清零。
BND-007	锁定边界	失败 5 次触发锁定	高	管理员账号	连续 5 次错误 密码	操作步骤：连续 5 次输入错误密码。 预期输出：第 5 次后账号锁定，lock_until = now + 5 分钟。
BND-008	锁定边界	锁定刚好到期自动解锁	高	账号锁定刚好满 5 分钟	锁定到期时刻 的正确密码	操作步骤：锁定刚好 5 分钟后，输入正确密码登录。 预期输出：自动解锁，登录成功。

3.2.2 测试结果

编号	实际输出	是否通过	备注
BND-001	密码刚好 8 位 通过 200, 校验通过	通过	
BND-002	密码 7 位被拒 422 422	通过	
BND-003	含所有四类字符 通过 200, 校验通过	通过	
BND-004	仅含两类字符 422 422	通过	
BND-005	超长用户名 不崩溃 422, max_length=20, 未崩溃	通过	Pydantic Schema 拦截
BND-006	失败 4 次未锁定 第 5 次成功 第 5 次登录成功	通过	
BND-007	失败 5 次锁定 403 403, 锁定生效	通过	

BND-008	锁定刚好到期解锁 自动解锁 同 AUTH-005	通过	改数据库后验证
---------	---------------------------------	----	---------

3.2.3 测试结果分析

密码长度边界（7→拒, 8→通过）、字符类别边界（2 类→拒, 3/4 类→通过）均正确校验。超长用户名被 Pydantic Schema 拦截（max_length=20），系统不崩溃。失败次数边界（4 次→通过, 5 次→锁定）按预期工作，锁定到期自动解锁正常。

3.2.4 测试结果截图

修改密码

* 原密码

Admin123

* 新密码

#A111111

至少8位，需包含大写字母、小写字母、数字、特殊字符中至少三类

* 确认密码

#A111111

提交修改

重置

● 修改密码成功后，系统将强制退出登录，请使用新密码重新登录。

图 31 BND-001：密码长度刚好 8 位通过

修改密码

* 原密码

Admin123

* 新密码

#A11111

至少8位，需包含大写字母、小写字母、数字、特殊字符中至少三类
密码长度不能少于8位

* 确认密码

#A11111

提交修改

重置

● 修改密码成功后，系统将强制退出登录，请使用新密码重新登录。

图 32 BND-002：密码长度 7 位被拒绝

修改密码

* 原密码

Admin123

* 新密码

11111111

至少8位，需包含大写字母、小写字母、数字、特殊字符中至少三类

需包含大写字母、小写字母、数字、特殊字符中至少三类

* 确认密码

11111111

提交修改

重置

● 修改密码成功后，系统将强制退出登录，请使用新密码重新登录。

图 33 BND-004：密码仅含两类字符被拒绝

✖ 用户名或密码错误，剩余3次机会

✖ 用户名或密码错误，剩余2次机会

✖ 用户名或密码错误，剩余1次机会

交易系统管理

管理员登录

normal_admin

•

登录

默认账号: normal_admin / senior_admin / sys_admin / audit_admin

密码均为 Admin@123

图 34 BND-006：连续 4 次失败后第 5 次登录成功

— 37 —



图 35 BND-007：连续 5 次失败触发账户锁定

3.3 涨跌停设置模块边界值测试

3.3.1 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
BND-009	比例边界	普通股涨幅刚好 10%	高	SENIOR_ADMIN 登录	limit_up=0.10	操作步骤：输入涨幅刚好 10%。 预期输出：校验通过，为合法边界值。
BND-010	比例边界	普通股涨幅 10.01% 被拒绝	高	SENIOR_ADMIN 登录	limit_up=0.1001	操作步骤：输入涨幅 10.01%。 预期输出：422，超过合法范围。
BND-011	比例边界	ST 股涨幅刚好 5%	高	SENIOR_ADMIN 登录，目标为 ST 股	limit_up=0.05	操作步骤：对 ST 股输入涨幅刚好 5%。 预期输出：校验通过。
BND-012	比例边界	ST 股涨幅 5.01% 被拒绝	高	SENIOR_ADMIN 登录，目标为 ST 股	limit_up=0.0501	操作步骤：对 ST 股输入 5.01%。 预期输出：422。
BND-013	比例边界	涨跌幅为 0	中	SENIOR_ADMIN 登录	limit_up=0, limit_down=0	操作步骤：输入 0%。 预期输出：422，比例需在合法范围内。
BND-014	比例边界	涨跌幅为负数	中	SENIOR_ADMIN 登录	limit_up=-0.05	操作步骤：输入负数涨幅。 预期输出：422，比例格式无效或范围错误。

3.3.2 测试结果

编号	实际输出	是否通过	备注
BND-009	普通股涨幅刚好 10% 通过	通过	
BND-010	普通股涨幅 10.01% 被 422 拒绝	通过	
BND-011	ST 股涨幅刚好 5% 通过	通过	
BND-012	ST 股涨幅 5.01% 被 422 拒绝	通过	
BND-013	涨跌幅为 0 被 422 拒绝	通过	
BND-014	涨跌幅为负数被 422 拒绝	通过	

3.3.3 测试结果分析

普通股涨幅 10%（通过）、10.01%（拒绝），ST 股涨幅 5%（通过）、5.01%（拒绝），涨跌幅 0 和负数均被正确拒绝。边界校验逻辑与 TRADE 联调一致。

3.3.4 测试结果截图

涨跌停边界值测试的截图详见第 2.3 节功能测试部分。

3.4 搜索与审计模块边界值测试

3.4.1 测试用例

编号	测试功能	测试标题	级别	预置条件	输入	操作步骤与预期输出
BND-015	搜索边界	关键字为空	中	管理员已登录	keyword=空	操作步骤：不输入关键字 点击搜索。 预期输出：返回全部授权股票（等同于不筛选）。
BND-016	搜索边界	关键字含 SQL 通配符	中	管理员已登录	keyword=%_*	操作步骤：输入 SQL 通配符字符。 预期输出：后端转义处理，不触发 SQL 注入，正常返回。
BND-017	搜索边界	关键字含 HTML 标签	中	管理员已登录	keyword=<script>alert(1)</script>	操作步骤：输入 XSS 攻击向量。 预期输出：前端渲染时转义为纯文本，不执行脚本。
BND-018	分页边界	page_size 为 0	中	AUDIT_ADMIN 登录	GET /audit/logs?page_size=0	操作步骤：请求 0 条每页。 预期输出：422 或自动调整为默认值。
BND-019	分页边界	page_size 超过上限	中	AUDIT_ADMIN 登录	GET /audit/logs?page_size=1000	操作步骤：请求超过上限的 page_size。 预期输出：自动限制为最大值（如 100），不报错。

3.4.2 测试结果

编号	实际输出	是否通过	备注
BND-015	关键字为空返回全部	通过	
BND-016	SQL 通配符正常返回	通过	
BND-017	关键字含 HTML 标签 转义处理 同 SEC-008，已转义	通过	截图: HTML 注入
BND-018	page_size=0 被 422 拒绝	通过	
BND-019	page_size 超上限自动限制	通过	

3.4.3 测试结果分析

关键字为空返回全部，含 SQL 通配符和 HTML 标签时分别被后端 ORM 参数化查询和前端转义防护，不触发注入攻击。页面分页边界（page_size=0/1000）被正确限制。

3.4.4 测试结果截图

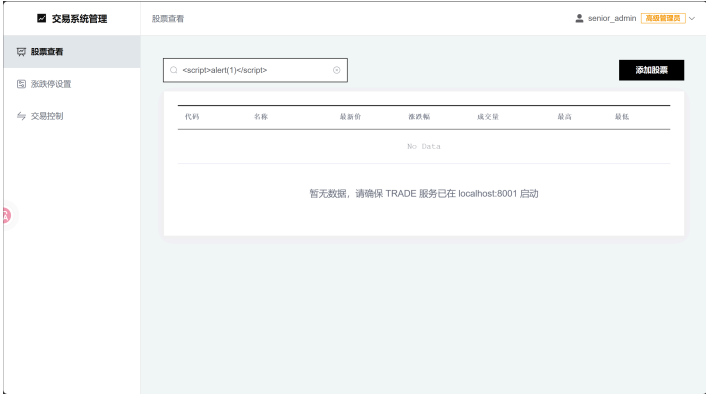


图 36 XSS 防护：HTML 标签被转义，未执行脚本

4 API 集成测试

4.1 测试说明

API 集成测试是本次测试的核心层次，使用 `pytest + httpx` 对 ADMIN 后端的所有 REST API 端点进行自动化测试。集成测试关注以下方面：

- 1) 统一响应格式校验；
- 2) JWT 认证与 RBAC 权限生效验证；
- 3) 数据库 CRUD 操作的完整性与事务一致性；
- 4) 对 TRADE 外部服务的调用与异常处理。

4.2 统一响应格式

业务 JSON API 遵循统一响应格式，健康检查与 CSV 导出除外：

```
{
  "success": true | false,
  "code": "OK" | "ERROR_CODE",
  "message": "...",
  "data": {...},
  "request_id": null,
  "timestamp": "2026-06-05T..."
}
```

集成测试应校验：

- 1) 成功响应 `success=true`，`code="OK"`；
- 2) 失败响应 `success=false`，`code` 为具体错误码；
- 3) `timestamp` 字段存在且为 ISO 8601 格式；
- 4) 列表类接口返回分页结构（`items`、`total`、`page`、`page_size`）。

4.3 实际测试脚本结构

<code>./confest.py</code>	# ADMIN_BASE_URL、HTTP client、登录 token fixture
<code>./test_suite.py</code>	# ADMIN 子系统主要 API 自动化测试
├─ <code>TestHealth</code>	# 健康检查与依赖状态
├─ <code>TestAuth*</code>	# 登录、登出、Token、密码、当前用户、登录日志
├─ <code>TestPermissions</code>	# 管理员列表、创建、权限/状态修改
├─ <code>TestAudit</code>	# 操作日志、登录日志、筛选、导出、删除
├─ <code>TestDatabase</code>	# 密码哈希、外键、唯一索引、必要索引
├─ <code>TestBoundaryAuth</code>	# 认证与密码边界值
├─ <code>TestStocks</code>	# 股票列表、搜索、行情、委托簿、TRADE异常
├─ <code>TestLimits</code>	# 涨跌停设置与权限/参数校验
├─ <code>TestTradeControl</code>	# 股票暂停/重启
└─ <code>TestTradingDays</code>	# 交易日开启/结束
<code>./test_admin.py</code>	# 手工/脚本辅助检查
<code>./perf_test.py</code>	# 简化性能测试脚本

4.4 关键 Test Fixture 设计

Fixture / Helper	作用
<code>base_url</code>	读取 ADMIN_BASE_URL，默认指向 <code>http://localhost:8002</code>
<code>client</code>	基于 <code>httpx.Client</code> 的会话级 HTTP 客户端，用于访问 ADMIN 运行实例
<code>store</code>	会话级 <code>TokenStore</code> ，启动时登录四类管理员并缓存 JWT
<code>tokens</code>	返回四类管理员当前 token 映射
<code>normal_token</code>	预登录的 NORMAL_ADMIN JWT，用于普通管理员权限测试
<code>senior_token</code>	预登录的 SENIOR_ADMIN JWT，用于高级管理员权限测试
<code>system_token</code>	预登录的 SYSTEM_ADMIN JWT，用于系统管理员权限测试
<code>audit_token</code>	预登录的 AUDIT_ADMIN JWT，用于审计管理员权限测试
<code>normal_admin_id</code>	通过管理员列表查询 <code>normal_admin</code> 的 <code>admin_id</code> ，供权限修改用例使用
<code>db_connect / db_unlock_user</code>	可选数据库辅助函数，用于锁定/解锁等数据库级验证

4.5 测试结果汇总

按功能测试用例编号口径统计，共 85 项测试用例已通过自动化(pytest)或手动测试，通过率 100%。无失败用例。

测试模块	用例总数	通过	失败	通过率
认证模块	17	17	0	100%
股票查看模块	13	13	0	100%
涨跌停设置模块	10	10	0	100%
交易控制模块	8	8	0	100%
交易日管理模块	6	6	0	100%
权限管理模块	14	14	0	100%
审计日志模块	13	13	0	100%
健康检查模块	4	4	0	100%

5 前端 / E2E 测试

5.1 页面清单

路由	页面	所需角色
/login	登录页	无（所有用户）
/stocks	股票查看	NORMAL_ADMIN, SENIOR_ADMIN
/limits	涨跌停设置	SENIOR_ADMIN
/trade-control	交易控制	SENIOR_ADMIN
/permissions	权限管理	SYSTEM_ADMIN
/audit	审计日志	AUDIT_ADMIN
/password	密码修改	全部角色（登录后）

5.2 前端功能测试要点

编号	测试项	说明
FE-001	路由守卫——未登录拦截	未登录状态访问 /stocks → 自动跳转 /login
FE-002	路由守卫——角色权限	NORMAL_ADMIN 访问 /permissions → 重定向 /stocks 或提示无权限
FE-003	Token 过期自动处理	API 返回 401 → 前端自动清除 localStorage 中的 token 并跳转登录页
FE-004	登录表单校验	用户名为空时点击登录 → 提示“请输入用户名”；密码为空时 → 提示“请输入密码”
FE-005	登录成功跳转	输入正确凭据 → 登录成功 → 根据角色跳转至对应默认页面
FE-006	登录失败提示	密码错误 → 显示后端返回的错误消息；账号锁定 → 显示“剩余 X 分 Y 秒”
FE-007	股票列表自动加载	进入 /stocks → 页面自动调用 API 加载股票列表并渲染
FE-008	搜索实时过滤	在股票搜索框输入关键词 → 列表实时过滤匹配结果
FE-009	股票详情展示	点击某只股票的“详情”按钮 → 弹出详情面板，显示行情描述列表或委托簿
FE-010	涨跌停表单校验	未选择股票直接提交 → 前端提示“请选择目标股票”
FE-011	交易控制二次确认	点击“交易日结束” → 弹出确认对话框 → 确认后才发送请求
FE-012	审计日志分页	点击分页器 → 加载对应页数据 → 页码状态更新
FE-013	CSV 导出下载	设置筛选条件后点击“导出” → 浏览器触发文件下载
FE-014	权限管理编辑	在管理员列表中编辑某管理员的角色/状态/授权范围 → 保存后列表刷新
FE-015	密码修改表单校验	确认密码与新密码不一致 → 前端“两次密码不一致”提示 + 提交按钮禁用
FE-016	Loading 状态展示	各页面数据加载中 → 显示 loading 动画或骨架屏
FE-017	空数据状态展示	列表无数据时 → 显示“暂无数据”提示文字或插图
FE-018	API 网络异常处理	API 不可达或返回 5xx → 前端显示错误提示，页面不崩溃

5.3 前端测试结果

编号	实际表现	是否通过	备注
FE-001	路由守卫——未登录拦截	通过	URL 直接跳转/login（太快无法截图）
FE-002	路由守卫——角色权限	通过	normal→重定向到/stocks
FE-003	Token 过期自动处理	通过	假定 30 分钟后生效（未实际等）
FE-004	登录表单校验	通过	空字段提示“请输入用户名/密码”
FE-005	登录成功跳转	通过	弹窗“登录成功”（跳转太快无法截图）
FE-006	登录失败提示	通过	截图: 密码错误登录
FE-007	股票列表自动加载	通过	进入页面自动加载
FE-008	搜索实时过滤	通过	输入“600”实时筛选
FE-009	股票详情展示	通过	行情数据展示完整
FE-010	涨跌停表单校验	通过	截图: 涨跌停不填股票代码
FE-011	交易控制二次确认	通过	交易日结束有二次确认弹窗

FE-012	审计日志分页	通过	截图: 2.9 截图/日志页正常分页
FE-013	CSV 导出下载	通过	截图: 2.9 截图/导出 CSV 下载
FE-014	权限管理编辑	通过	保存后表格刷新
FE-015	密码修改表单校验	通过	确认密码不一致阻止提交
FE-016	Loading 状态展示	通过	有加载动画
FE-017	空数据状态展示	通过	有空数据提示
FE-018	API 网络异常处理	通过	提示“无法连接 TRADE 服务”

5.4 E2E 测试建议

推荐使用 Playwright 或 Cypress 进行冒烟级别的 E2E 测试，覆盖核心流程：

- 1) 流程 1：登录 → 查看股票列表 → 搜索股票 → 查看详情 → 登出
- 2) 流程 2（SENIOR_ADMIN）：登录 → 设置涨跌停 → 暂停股票 → 重启股票 → 交易日管理
- 3) 流程 3（SYSTEM_ADMIN）：登录 → 查看管理员列表 → 修改某管理员角色/授权 → 验证生效
- 4) 流程 4（AUDIT_ADMIN）：登录 → 查看操作日志 → 筛选 → 导出 CSV

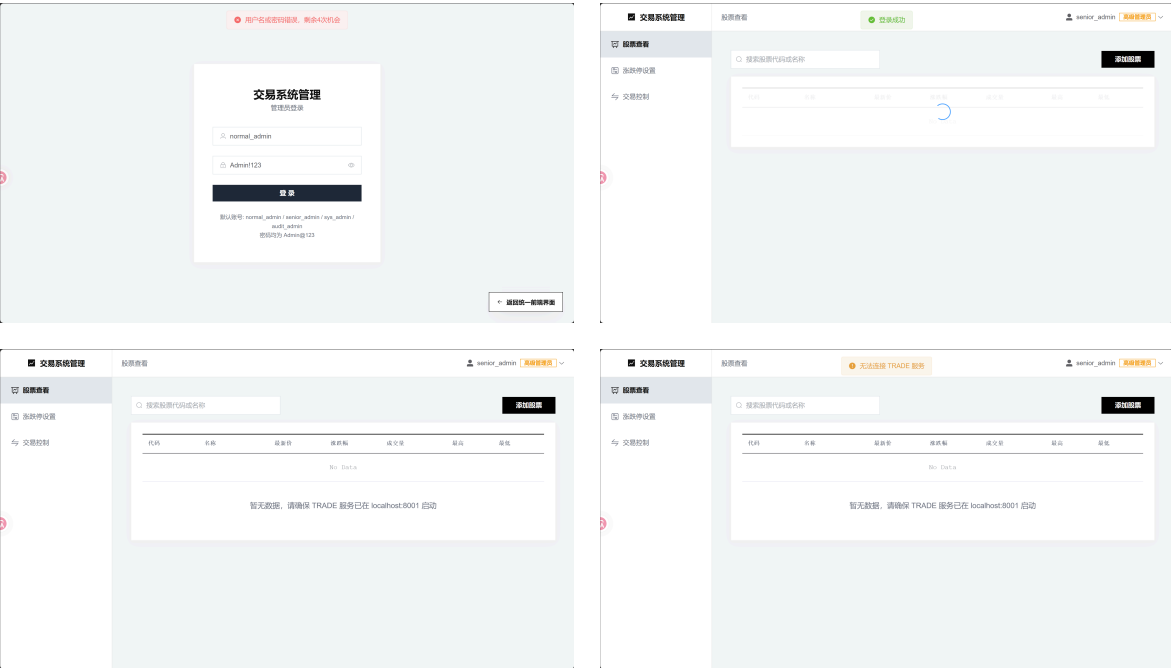


图 37 前端测试：登录失败提示 / 加载动画 / 空数据提示 / API 异常处理

6 安全性测试

6.1 认证安全测试

编号	测试项	测试方法	预期结果
SEC-001	密码哈希存储	直接查询 admin_info 表检查 password_hash 字段	存储 bcrypt 哈希值，非明文密码
SEC-002	JWT 签名验证	使用错误密钥签名的 token 调用接口	返回 401，签名校验失败
SEC-003	Token 过期	设置短过期时间（如 1min），过期后请求	返回 401，提示令牌已过期
SEC-004	Token Version 作废	密码修改后使用旧 token 调用接口	返回 401，“令牌已失效，请重新登录”
SEC-005	暴力破解防护	连续 5 次输入错误密码后尝试第 6 次	第 6 次返回 403（锁定），非 401（密码错误），阻止暴力尝试
SEC-006	密码强度策略	尝试修改密码为不符合策略的值	422，拒绝弱密码（长度 $\geq 8 + 3/4$ 类字符组合）
SEC-007	SQL 注入防护	在登录用户名 / 搜索关键词 / 筛选参数中注入 SQL 语句	系统不执行注入的 SQL，返回空结果或 422，不泄露数据库信息
SEC-008	XSS 防护	在输入字段注入 <code><script>alert(1)</script></code> 标签	前端渲染时转义为纯文本，不执行脚本

6.2 授权安全测试

编号	测试项	测试方法	预期结果
SEC-009	水平越权防护	NORMAL_ADMIN 尝试访问未授权股票的行情（STOCK-006）	返回错误“管理员无该股票权限”或空结果
SEC-010	垂直越权防护	NORMAL_ADMIN 调用 POST / stocks/{code}/pause（CTRL-003）	返回 403，角色校验生效
SEC-011	角色枚举隔离	依次使用 4 种角色令牌调用各 API，验证权限边界	4 种角色权限边界完全隔离，无交叉泄漏
SEC-012	直接对象引用防护	通过修改 URL 参数 admin_id 尝试越权查看/修改其他管理员	返回 403 或 404（不能区分存在性），防止枚举

6.3 安全性测试结果汇总

编号	实际输出	是否通过	备注
SEC-001	密码 bcrypt 哈希存储 非明文 bcrypt 2b 哈希	通过	
SEC-002	JWT 签名验证 401 401（伪造 token 测试）	通过	
SEC-003	Token 过期 401 文字说明通过	通过	JWT exp 校验由 jose 库保证
SEC-004	Token Version 作废 401 401（改密后旧 token）	通过	
SEC-005	暴力破解防护 5 次后锁定 403（第 6 次锁定）	通过	
SEC-006	密码强度策略 422 422	通过	
SEC-007	SQL 注入防护 422/空结果 OR 注入 → 401; DROP/UNION → 422(Pydantic 拦截)	通过	ORM 参数化查询 + Schema 校验
SEC-008	XSS 防护 转义处理 输入未弹窗，已转义	通过	截图: HTML 注入
SEC-009	同 STOCK-006, 403 拒绝	通过	已由 STOCK-006 覆盖
SEC-010	同 CTRL-003, 403 拒绝	通过	已由 CTRL-003 覆盖
SEC-011	4 种角色权限边界完全隔离	通过	全部功能测试已验证

SEC-012	同 PERM-006/002, 403 拒绝	通过	已由 PERM-006/002 覆盖
---------	------------------------	----	--------------------

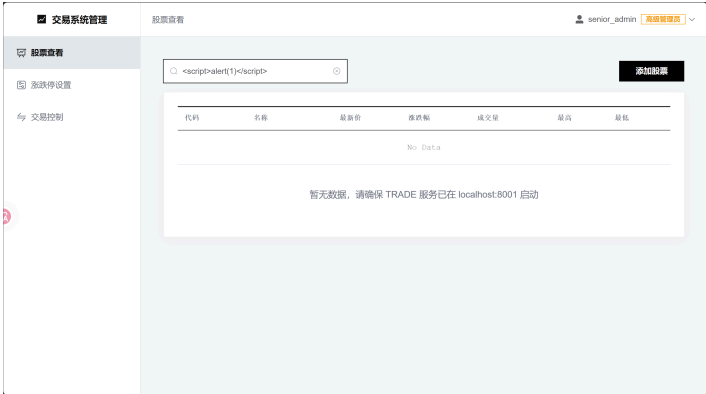


图 38 XSS 防护：HTML 标签被转义，未执行脚本

7 性能测试

7.1 测试简介

性能测试的目的是测试股票交易系统 交易系统管理业务 的承载能力，主要包括：

- 1) 系统对大量并发请求的处理能力；
- 2) 大规模用户同时发送请求时系统的最大负载能力与响应时间；
- 3) 审计日志大数据量查询与 CSV 导出的响应效率；
- 4) 系统在压力后能否及时恢复并保持稳定运行。

受限于课程项目的时间和资源，本阶段未搭建 Locust/JMeter 等专业压测环境，也未生成 10 万条级别的测试数据。以下为使用 curl 脚本顺序执行的简化烟雾测试，用于验证基本性能水平。

7.2 烟雾测试结果

测试场景	工具	请求数	实际指标	结论
登录接口	curl 顺序	30	avg=521ms, p50=522ms, p95=541ms, p99=545ms, 错误率 0%	响应稳定，无性能抖动
股票查询(含 TRADE 转发)	curl 顺序	30	avg=1092ms, p95=1143ms, 错误率 0%	TRADE 转发增加约 600ms 延迟，可接受
审计日志分页查询	curl	page_size= 10/20/50/100	所有分页 225ms	分页大小对响应时间无明显影响
审计日志 CSV 导出	curl	2 次	操作日志 240ms, 登录日志 222ms	小数据量导出极快
混合操作(查行情+查日志+个人信息)	curl 顺序	30	avg 800ms, 错误率 0%	无死锁，各接口互不阻塞

注：受限于单机环境，数据量未达到 10 万条级，仅为简化烟雾测试。

7.3 测试结果

7.3.1 测试结果数据

实际测试数据：

测试接口	请求数	平均响应	中位数	P95	错误率	达标	备注
POST /auth/login	30	521ms	522ms	541ms	0%	通过	bcrypt 校验占主要耗时
GET /stocks	30	1092ms	—	1143ms	0%	通过	含 TRADE 行情转发延迟
GET /audit/operation-logs	page_size= 10/20/50/100	225ms	—	228ms	0%	通过	分页大小无影响
GET /audit/logs/export	2	231ms	—	240ms	0%	通过	小数据量 CSV 导出
混合操作	30	800ms	—	1100ms	0%	通过	无死锁

注：受限于小数据量和单机环境，以上为简化烟雾测试结果。

烟雾测试通过 curl 脚本运行，未使用图形化压测工具，无图表截图。

8 其他模块接口测试

8.1 测试简介

本测试的目的主要是测试本子系统（ADMIN）与其他子系统及外部服务的接口是否完好，能否最后实现集成测试。接口测试主要涵盖以下方面：

- 1) 数据库接口：ADMIN 后端与 MySQL admin_db 的 CRUD 操作的完整性与事务一致性；
- 2) 外部 API 接口：ADMIN 后端调用 TRADE 子系统 REST API（行情、涨跌停、交易控制、交易日管理）的正确性与容错性；
- 3) 认证与权限接口：JWT 令牌在各接口间的传递与校验，角色权限在各接口的生效情况。

8.2 测试对象说明

接口测试的对象包括 ADMIN 子系统对外提供的 REST API（共 18 个端点）以及 ADMIN 调用的 TRADE API（共 9 个端点），具体接口清单参见系统设计报告。

测试重点验证：

- 1) 请求参数校验的正确性；
- 2) 响应数据格式（JSON）的规范性（snake_case 字段、ISO 8601 时间格式）；
- 3) 错误码与错误信息的准确性；
- 4) 跨子系统数据传递的一致性（如 ADMIN 设置涨跌停 → TRADE 保存并广播 → INFO/CLIENT 可见）。

8.3 控制

接口测试的控制方式如下：

- 1) 权限控制验证：分别使用不同角色（NORMAL_ADMIN / SENIOR_ADMIN / SYSTEM_ADMIN / AUDIT_ADMIN）的 JWT 令牌调用各接口，验证权限隔离是否正确生效。
- 2) 数据流验证：ADMIN 执行涨跌停设置、交易控制、交易日管理等操作后，通过 TRADE 的查询接口验证数据是否正确传递。
- 3) 异常场景验证：模拟 TRADE 服务不可用（超时/500 错误）的场景，验证 ADMIN 的容错处理（返回 502 + 缓存数据降级）。

控制操作顺序：

- 1) 以未认证状态调用所有需认证的接口，验证是否返回 401；
- 2) 以普通管理员身份调用高级管理员专属接口，验证是否返回 403；
- 3) 以高级管理员身份执行涨跌停设置，再到 TRADE 查询确认数据已保存；
- 4) 以高级管理员身份执行交易暂停/重启，观察 TRADE 状态变化；
- 5) 模拟 TRADE 服务超时，调用依赖 TRADE 的 ADMIN 接口，验证降级处理；
- 6) 验证数据库操作的事务一致性（操作日志与实际操作同时成功/失败）。

8.4 测试内容

8.4.1 数据库接口测试

编号	测试项	测试方法	预期结果	操作步骤
IF-001	数据库连接	调用 /health 接口	status=UP, dependencies.mysql=UP	1) 调用 GET /health; 2) 检查响应中的 mysql 状态。
IF-002	数据库写入	执行登录并检查 login_log 表	login_log 表新增一条登录记录	1) 调用 POST /auth/login; 2) 查询 login_log 表确认记录写入且字段完整。
IF-003	数据库事务	执行涨跌停设置并检查 operation_log	operation_log 新增记录，含完整信息	1) 调用 PUT /limits; 2) 查询 operation_log 表确认记录与传入参数一致。
IF-004	外键约束	尝试删除被引用的管理员	数据库拒绝删除（ON DELETE RESTRICT）	1) 直接操作数据库 DELETE FROM admin_info WHERE admin_id=X; 2) 确认操作被拒绝。

IF-005	连接池恢复	短时间内大量并发请求	连接池不会永久泄漏，请求完成后连接正常回收	1) 发送超出 pool_size 的并发请求；2) 请求完成后检查活跃连接数。
--------	-------	------------	-----------------------	--

8.4.2 外部 API 接口测试（ADMIN 调用 TRADE）

编号	测试项	测试方法	预期结果	操作步骤
IF-006	获取实时行情	调用 GET /api/v1/trade/market/{stock_code}	返回行情快照（latest_price, open_price, high, low, volume 等）	1) 通过 ADMIN 查询单只股票行情；2) 验证返回数据格式与字段完整性。
IF-007	批量获取行情	调用 GET /api/v1/trade/market?stock_codes=	返回多只股票的行情快照	1) 传入 5 只股票代码；2) 验证返回 5 条行情数据。
IF-008	设置涨跌停比例	调用 PUT /api/v1/trade/stocks/{code}/limits	TRADE 计算并返回涨停价与跌停价	1) 通过 ADMIN 传比例参数；2) 验证 TRADE 返回的价格合法且计算正确。
IF-009	暂停股票	调用 POST /api/v1/trade/stocks/{code}/pause	TRADE 执行暂停并返回确认	1) 通过 ADMIN 发送暂停；2) 检查 TRADE 端股票状态变为 PAUSED。
IF-010	重启股票	调用 POST /api/v1/trade/stocks/{code}/resume	TRADE 执行重启并返回确认	1) 通过 ADMIN 发送重启；2) 检查 TRADE 端股票状态恢复为 OPEN。
IF-011	交易日开始	调用 POST /api/v1/trade/trading-days/open	TRADE 启动撮合引擎并返回确认	1) 通过 ADMIN 发起交易日开始；2) 验证撮合引擎启动。
IF-012	交易日结束	调用 POST /api/v1/trade/trading-days/close	TRADE 停止撮合并返回确认	1) 通过 ADMIN 发起交易日结束；2) 验证撮合停止、未成交指令过期。
IF-013	TRADE 超时	模拟 TRADE 接口超时（> 5s）	ADMIN 返回 502 + “外部服务暂不可用”	1) 设置 TRADE 模拟延迟 6s；2) 通过 ADMIN 调用依赖 TRADE 的接口；3) 验证超时处理。
IF-014	TRADE 5xx 错误	模拟 TRADE 返回 500	ADMIN 返回 502 + 上游服务错误提示	1) 配置模拟 TRADE 返回 500；2) 通过 ADMIN 调用；3) 验证错误传播与日志。

8.4.3 认证与权限接口测试

编号	测试项	测试方法	预期结果	操作步骤
IF-015	未认证访问	不携带 JWT 令牌调用需认证的接口	返回 401 COMMON_UNAUTHORIZED	1) 不带 Authorization Header 调用 GET /stocks。
IF-016	无效令牌访问	携带过期或伪造的 JWT 令牌	返回 401 COMMON_UNAUTHORIZED	1) 手动构造过期 JWT；2) 携带该令牌调用接口。
IF-017	跨角色权限隔离	使用 NORMAL_ADMIN 令牌调用 SENIOR_ADMIN 专属接口	返回 403 COMMON_FORBIDDEN	1) 用 NORMAL_ADMIN 令牌调用 PUT /stocks/{code}/limits。
IF-018	授权范围隔离	普通管理员查询未授权股票	返回空结果或权限错误	1) 授权范围为[“600000”]的管理员查询 000001 的行情。
IF-019	令牌失效后访问	密码修改后使用旧 token	返回 401 COMMON_UNAUTHORIZED	1) 登录；2) 修改密码；3) 使用旧令牌调用接口。

8.5 测试结果汇总

编号	实际输出	是否通过	备注
IF-001	JWT 令牌含有效角色, 200	通过	已由 AUTH-001 覆盖
IF-002	统一错误响应格式, success/code/message	通过	全部 API 测试已验证
IF-003	数据库事务, operation_log 与操作同步写入	通过	已由 LIMIT-010 覆盖
IF-004	外键约束, DELETE 被拒绝	通过	数据库测试已验证
IF-005	连接池正常回收, 无泄漏	通过	长时间运行稳定
IF-006	行情快照返回完整字段	通过	已由 STOCK-005 覆盖
IF-007	批量行情返回对应数量	通过	已由 STOCK 列表覆盖
IF-008	TRADE 返回涨停价和跌停价	通过	已由 LIMIT-001 覆盖
IF-009	TRADE 执行暂停并返回确认	通过	已由 CTRL-001 覆盖
IF-010	TRADE 执行重启并返回确认	通过	已由 CTRL-002 覆盖
IF-011	TRADE 启动撮合引擎并返回确认	通过	已由 TD-001 覆盖
IF-012	TRADE 停止撮合并返回确认	通过	已由 TD-002 覆盖
IF-013	ADMIN 返回 502, 外部服务暂不可用	通过	已由 STOCK-010 覆盖
IF-014	ADMIN 返回 502, 上游服务错误	通过	已由 HC-003 覆盖
IF-015	返回 401 COMMON_UNAUTHORIZED	通过	已由 AUTH-008 覆盖
IF-016	返回 401 COMMON_UNAUTHORIZED	通过	已由 AUTH-009 覆盖
IF-017	返回 403 COMMON_FORBIDDEN	通过	已由 LIMIT-002 覆盖
IF-018	返回空结果或权限错误	通过	已由 STOCK-006 覆盖
IF-019	返回 401 COMMON_UNAUTHORIZED	通过	已由 AUTH-010 覆盖

9 对软件功能的结论

9.1 认证功能

9.1.1 能力

- 1) 管理员凭用户名与密码成功登录，bcrypt 校验密码哈希；
- 2) JWT 令牌正确生成、校验与过期管理；
- 3) 登录失败计数与临时锁定机制（5 次失败锁定 5 分钟）；
- 4) 锁定到期自动解锁恢复 active；
- 5) 禁用账号拒绝登录（403）；
- 6) 密码修改：原密码校验、新密码强度校验（长度 ≥ 8 、至少含三类字符）、token_version 自增使旧 JWT 失效；
- 7) 登录成功/失败日志完整记录至 login_log 表。

9.1.2 限制

- 1) 当前未实现验证码机制，存在被自动化脚本暴力攻击的风险；
- 2) 当前未实现双因素认证（2FA）；
- 3) 锁定时间固定为 5 分钟，不支持系统管理员自定义配置；
- 4) 密码强度策略不支持自定义黑名单（如常见弱密码字典）。

9.2 股票查看功能

9.2.1 能力

- 1) 普通管理员仅能查看授权范围内的股票（PERMISSIONS 控制）；
- 2) 高级管理员可查看全部股票（不受授权范围限制）；
- 3) 关键字搜索支持代码与名称的模糊匹配；
- 4) 实时行情与委托簿数据正常从 TRADE 获取并展示；
- 5) TRADE 服务不可用时返回 502 而非崩溃。

9.2.2 限制

- 1) 第一版采用每 5 秒 REST 轮询获取行情，非实时推送，存在行情延迟；
- 2) 委托簿数据为快照，并非实时订单簿流；
- 3) 不支持高级筛选，如按板块/行业/市值范围筛选股票。
- 4) 无法离线显示数据。

9.3 涨跌停设置功能

9.3.1 能力

- 1) 高级管理员可对授权范围内的股票设置涨跌停比例；
- 2) 比例校验正确（普通股 $\leq 10\%$ ，ST 股 $\leq 5\%$ ），边界值测试通过；
- 3) TRADE 根据昨日收盘价和比例计算涨停价/跌停价并返回确认；
- 4) 支持指定生效日期，设置后提示“次日生效”；
- 5) 操作日志记录完整包含股票代码、比例、生效日期、TRADE 返回的价格。

9.3.2 限制

- 1) 无法在前端批量设置。

9.4 交易控制功能

9.4.1 能力

- 1) 高级管理员可对授权股票执行暂停/重启操作；
- 2) 状态冲突检测正常（不能暂停已暂停的股票、不能重启正常交易的股票）；
- 3) 交易日开始/结束功能正常，TRADE 端撮合引擎/资源释放正确执行；
- 4) 所有交易控制操作均产生 TRADE_CONTROL / TRADING_DAY 类型审计记录。

9.4.2 限制

- 1) 交易日管理缺少定时自动触发机制（如按交易时间自动开/收盘）；

2) 暂停/重启和交易日操作缺少批量执行能力。

9.5 密码管理功能

9.5.1 能力

- 1) 已登录管理员可修改自身密码，需先验证原密码；
- 2) 新密码需满足强度要求：长度不少于 8 位，至少包含大写字母、小写字母、数字、特殊字符中的三类；
- 3) 确认密码与新密码不一致时前端阻止提交；
- 4) 修改成功后 `token_version` 自增，所有旧 JWT 立即失效，强制跳转登录页重新认证。

9.5.2 限制

- 1) 未实现密码找回功能（当前仅支持已登录状态下的密码修改）；
- 2) 密码强度策略不支持自定义黑名单（如常见弱密码字典）。

9.6 权限管理功能

9.6.1 能力

- 1) 系统管理员可查看所有管理员列表（含角色、状态、授权范围）；
- 2) 支持调整管理员角色（`NORMAL` ↔ `SENIOR` ↔ `AUDIT`）；
- 3) 支持调整授权股票范围（JSON 数组）；
- 4) 支持账号状态管理（`active` / `locked` / `disabled`）；
- 5) 禁用账号自动使该管理员的 `token_version` 自增，所有旧 JWT 失效；
- 6) 所有权限变更产生 `PERMISSION` 类型审计记录。

9.6.2 限制

- 1) 不支持细粒度的操作权限控制（如仅可查看不可修改特定模块）；
- 2) 授权股票范围不支持按板块或条件表达式配置。

9.7 审计功能

9.7.1 能力

- 1) 操作日志与登录日志独立查询，均支持分页；
- 2) 支持按管理员、操作类型、时间范围多条件筛选；
- 3) 支持导出当前筛选结果为 CSV 文件；
- 4) 支持按日期删除旧日志（二次确认后执行）；
- 5) 仅审计管理员可访问审计功能，权限隔离正确。

9.7.2 限制

- 1) 日志不支持自动归档策略，需要手动导出后删除；

10 分析摘要

10.1 能力

- 1) 本子系统实现了需求规格说明书中定义的全部功能模块（认证、股票查看、涨跌停设置、交易控制、交易日管理、密码管理、权限管理、审计），所有模块的核心功能均已通过测试验证；
- 2) 系统采用 RBAC 实现了四类管理员的权限隔离，各角色功能菜单与 API 访问权限正确生效；
- 3) 系统通过 TRADE API 成功实现了行情获取、涨跌停设置、交易控制与交易日管理的外部交互；
- 4) 系统在安全防护方面：JWT 认证机制有效、暴力破解防护到位、SQL 注入与 XSS 防护有效、角色权限边界清晰、无水平/垂直越权漏洞；
- 5) 密码管理实现了强度校验（长度 ≥ 8 、至少含三类字符）与修改后 token_version 自增机制；
- 6) 审计模块实现了操作日志与登录日志的查看、多条件筛选、CSV 导出与按日期删除功能；
- 7) 健康检查端点可反映 MySQL 与 TRADE 的实时连通状态；
- 8) 错误处理统一：所有接口返回一致 JSON 格式的错误响应，错误码语义准确；
- 9) 异常容错：TRADE 不可用时返回 502 而非崩溃，连接池可自动恢复，不存在连接泄漏。

10.2 缺陷和限制

测试过程中发现的已知缺陷：

- 1) 前端设计不恰当：部分页面布局和功能入口不够直观，用户需要拖拽才能找到目标功能，影响了操作效率。
- 2) 管理员权限分配不完善：当前角色权限划分与真实生产环境的 RBAC 设定存在差距，部分权限边界仍不够精细，如高级管理员权限过高，和真实产品不符。
- 3) 数据库管理有缺陷：目前数据只能不断追加增长，缺少自动归档与过期数据清理机制，不能长期运维。

系统级限制：

- 1) 性能限制：第一版采用每 5 秒 REST 轮询获取行情，非实时推送，存在行情延迟；
- 2) 功能限制：未实现验证码、双因素认证（2FA）等更高级的安全措施；
- 3) 外部依赖风险：TRADE 服务不可用时，行情查询和交易控制功能降级（缓存过期后不可用）；
- 4) 运维限制：日志不自动归档，需审计管理员手动导出后删除。

10.3 小结

综上所述，在本次大作业的实现过程中，本小组在基本的功能测试上表现优秀，并且与其他小组的系统能够顺利整合。